

CCSK Bootcamp Day 2

- 7. Infrastructure & Networking
- 8. Cloud Workload Security
- 9. Data Security
- 10. Application Security
- 11. Incident Response & Resilience
- 12. Related Technologies & Strategies





CSP Infrastructure

Security Responsibilities

- **Facilities:** The CSP is responsible for ensuring the physical security of the facilities where the cloud infrastructure is housed. This includes measures like access control, surveillance, and environmental protection
- **Employees:** The CSP screens, trains, and manages employees with access to cloud infrastructure, helping maintain organization integrity and trustworthiness
- **Physical network, storage, and compute:** The CSP secures and maintains the underlying physical components of the cloud infrastructure, such as servers, storage devices, and networking equipment

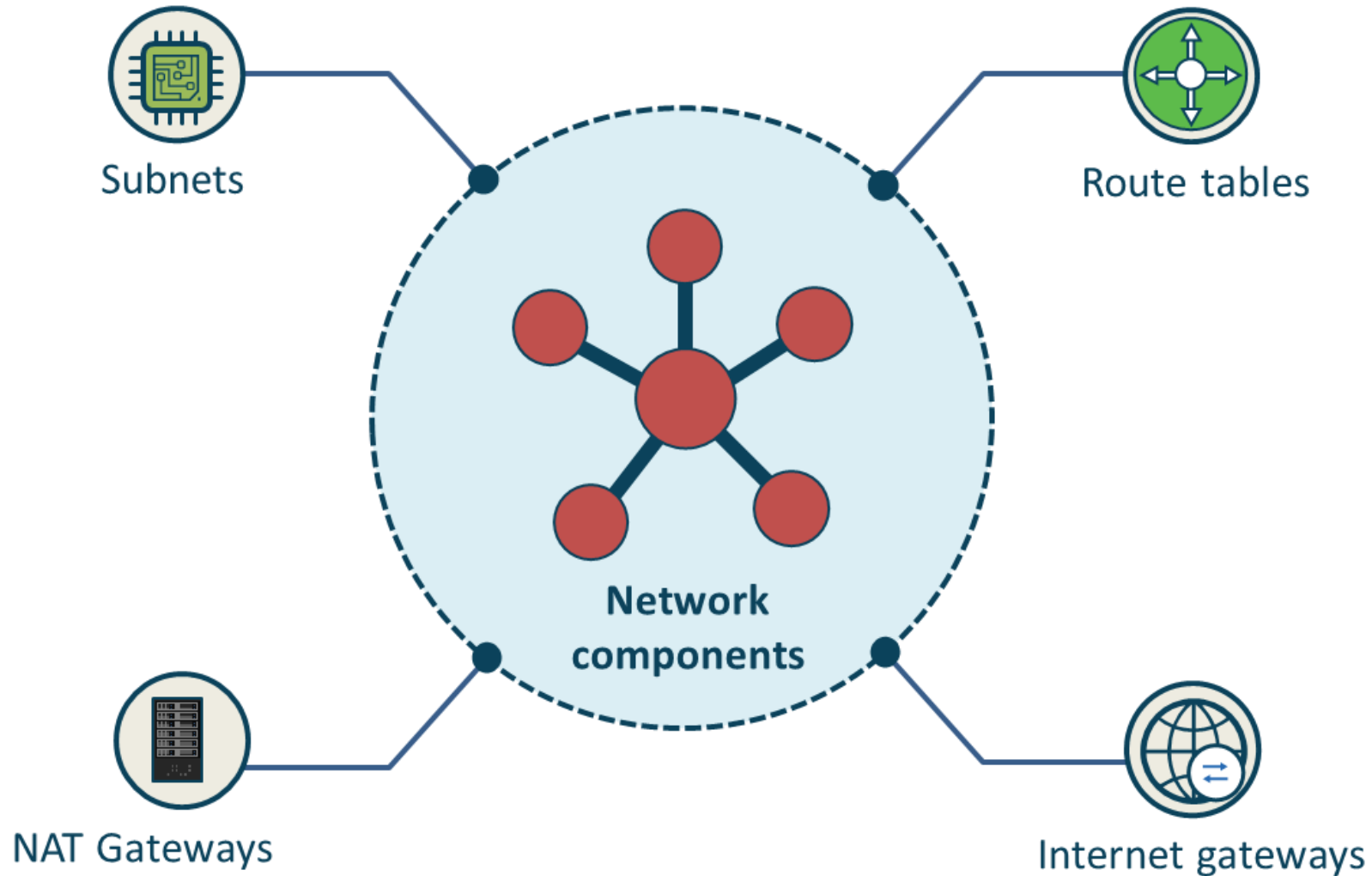
CSP Infrastructure

Security Responsibilities

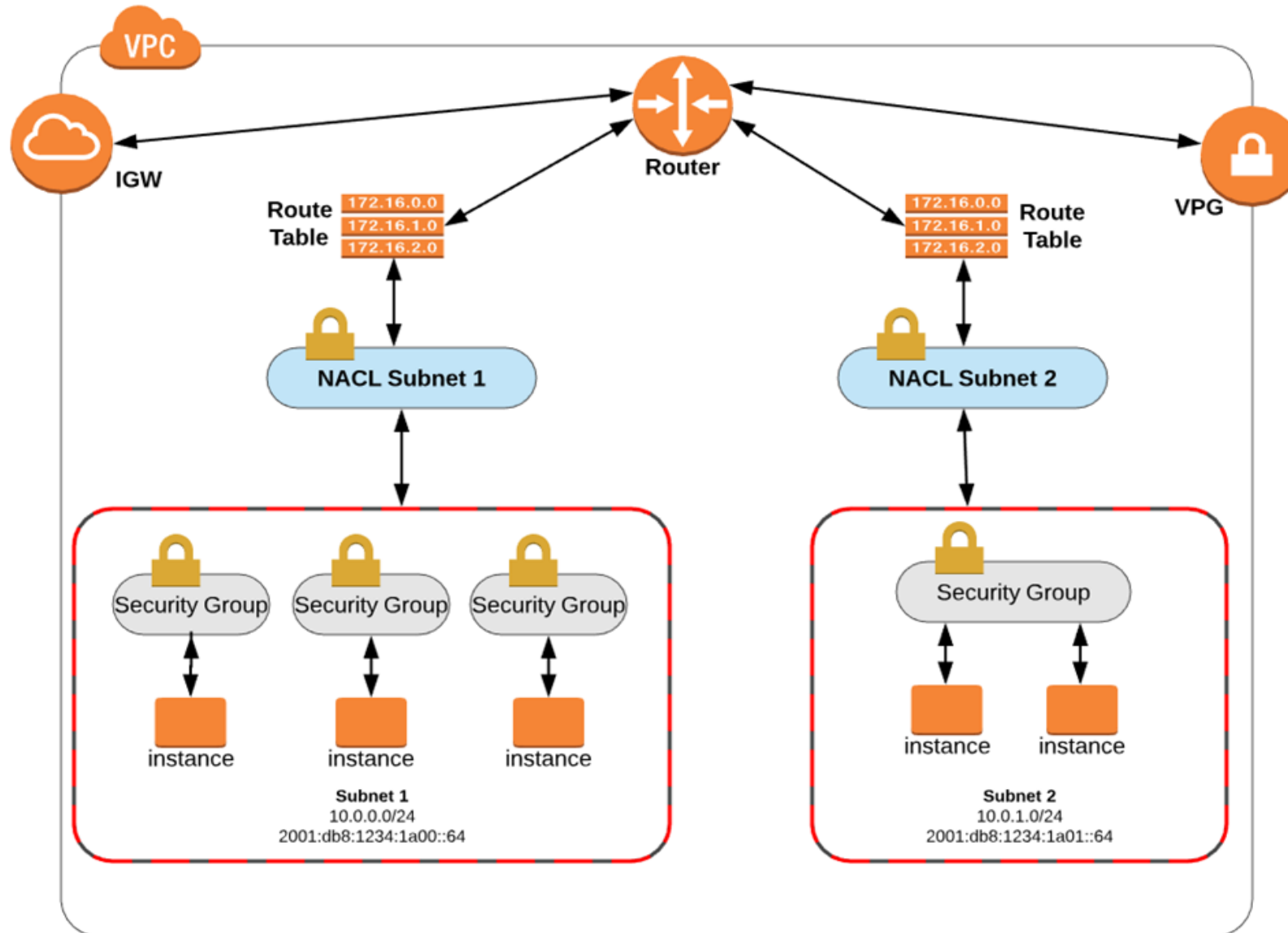


- **Virtualization layers:** CSPs are responsible for securing the virtualization that enables the creation and isolation of VMs and containers running on the physical infrastructure. Server virtualization is typically done through a hypervisor
- **Management plane:** The CSP secures and controls access to the web-based interfaces and API endpoints (metastructure) that customers use to manage their cloud resources and services
- **PaaS and SaaS services:** The CSP offers higher-level platforms and software services that handle the security of the underlying infrastructure and applications based on the shared responsibility model

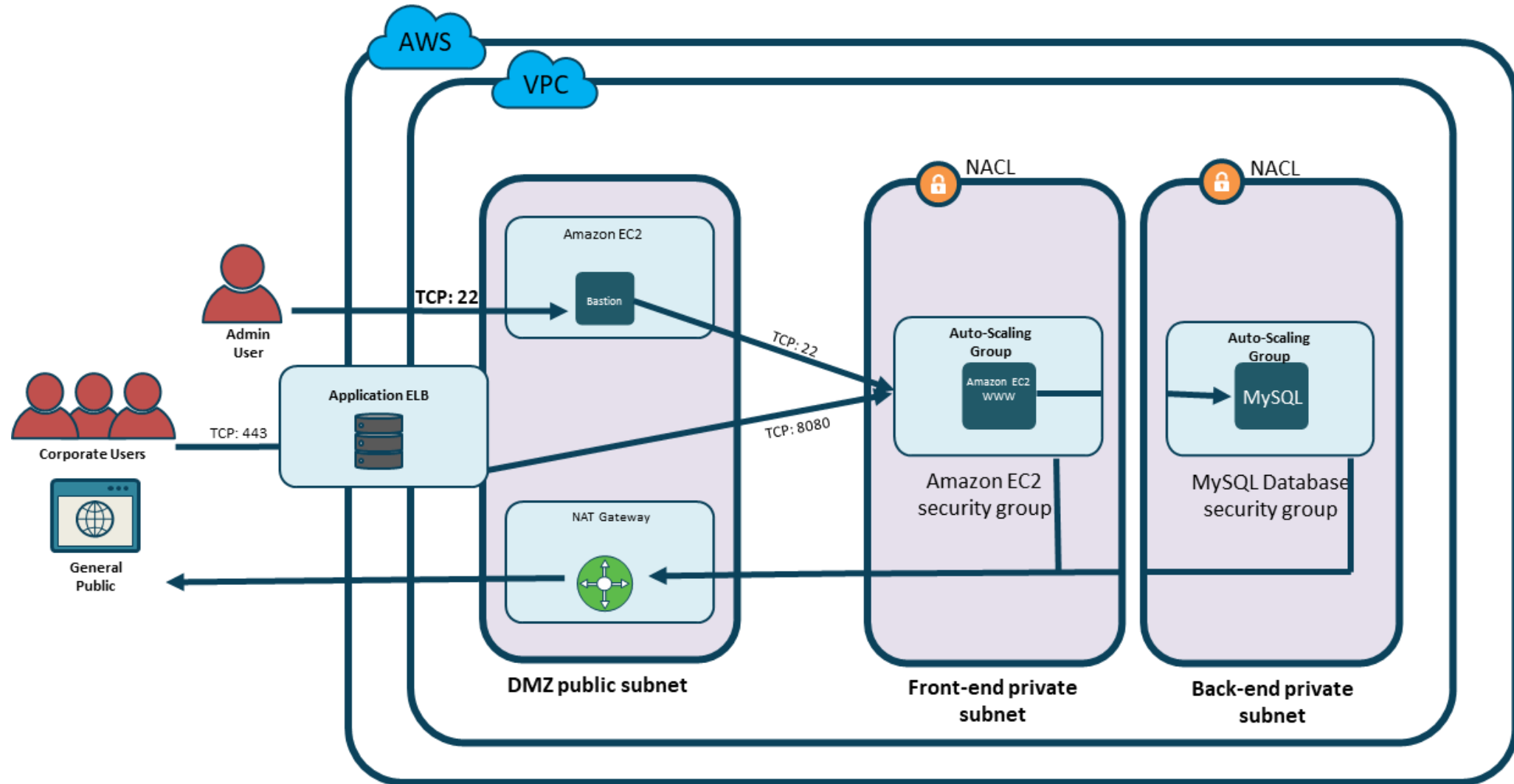
Networking Fundamentals



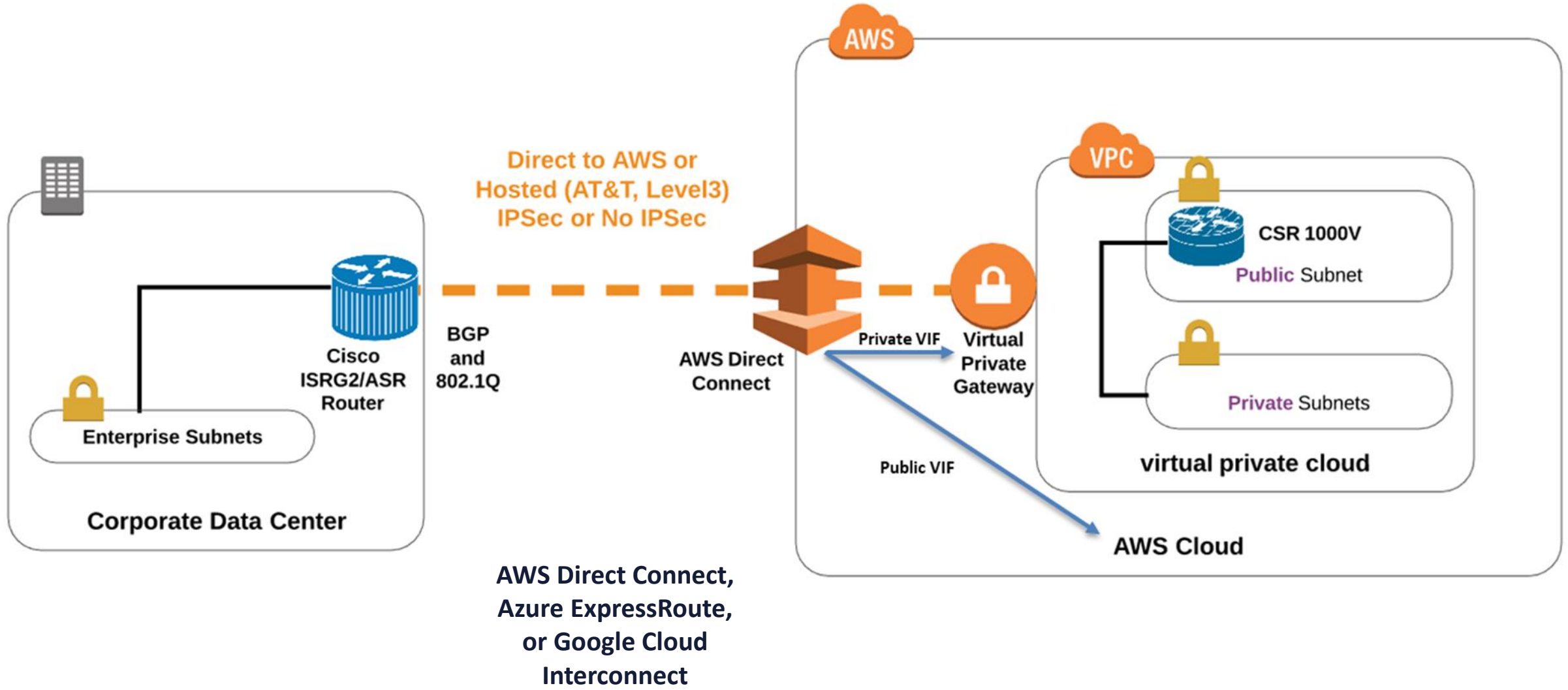
Customer Networking Begins with Design



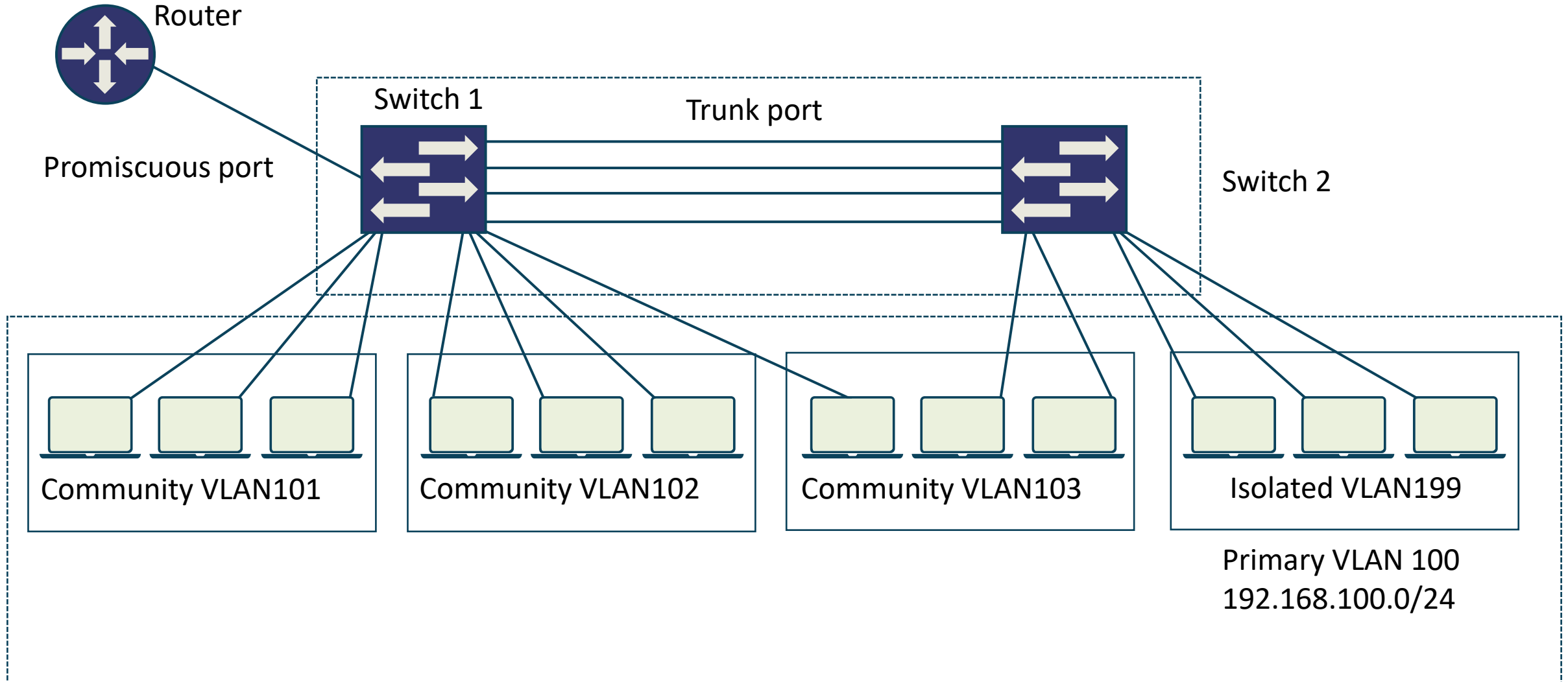
Customer Networking Begins with Design



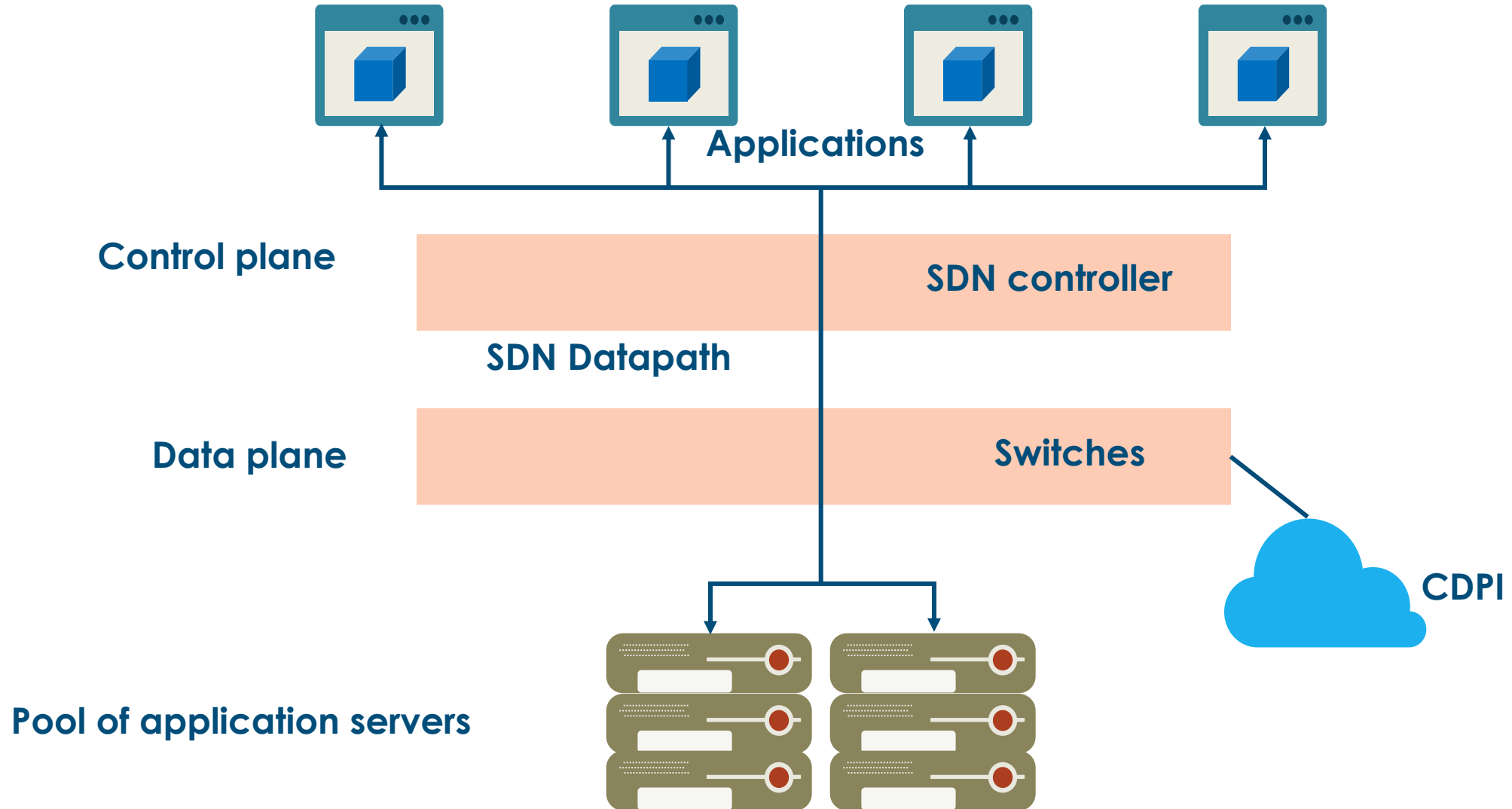
CSP Direct Solutions (for edge and hybrid cloud)



PVLANs for Segmentation and Containment



Software-defined Networking (SDN)

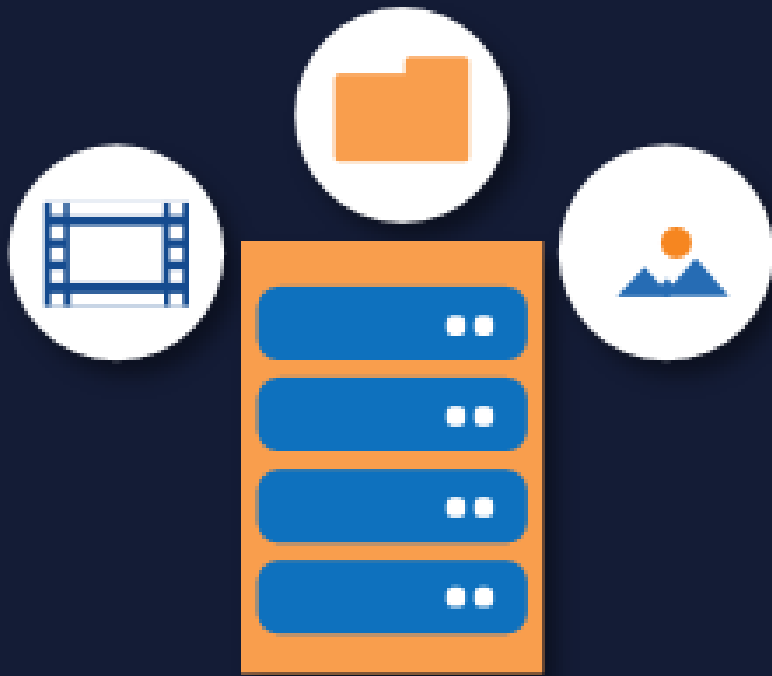


Software-defined Networking (SDN)

- **Directly programmable:** Network control is directly programmable because it is decoupled from forwarding functions.
 - SDN lets network managers configure, manage, secure, and optimize network resources very quickly via dynamic, automated SDN programs, which they can write themselves because the programs do not depend on proprietary software
- **Agile:** Abstracting control from forwarding lets administrators dynamically adjust network-wide traffic flow to meet changing needs



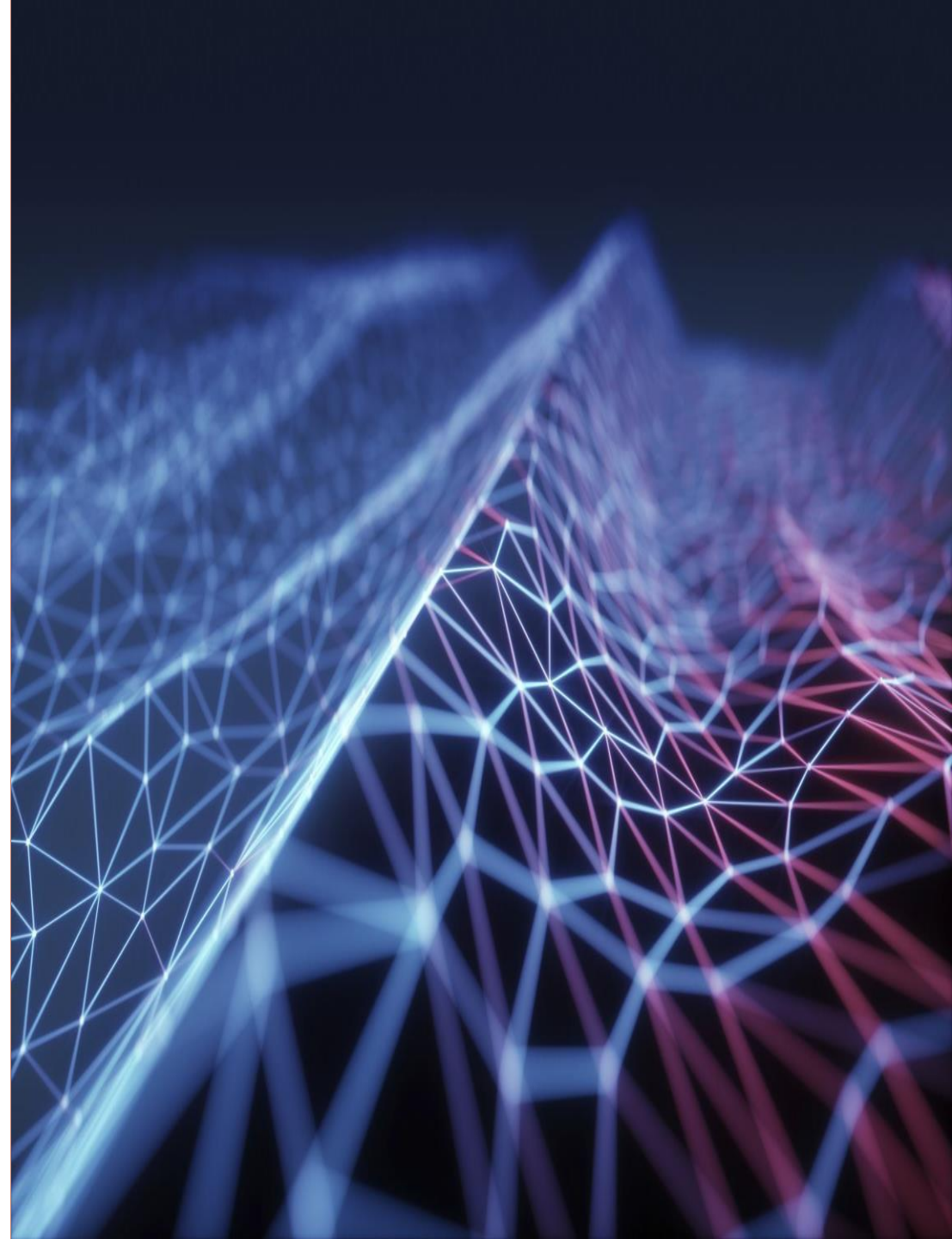
Software-defined Networking (SDN)



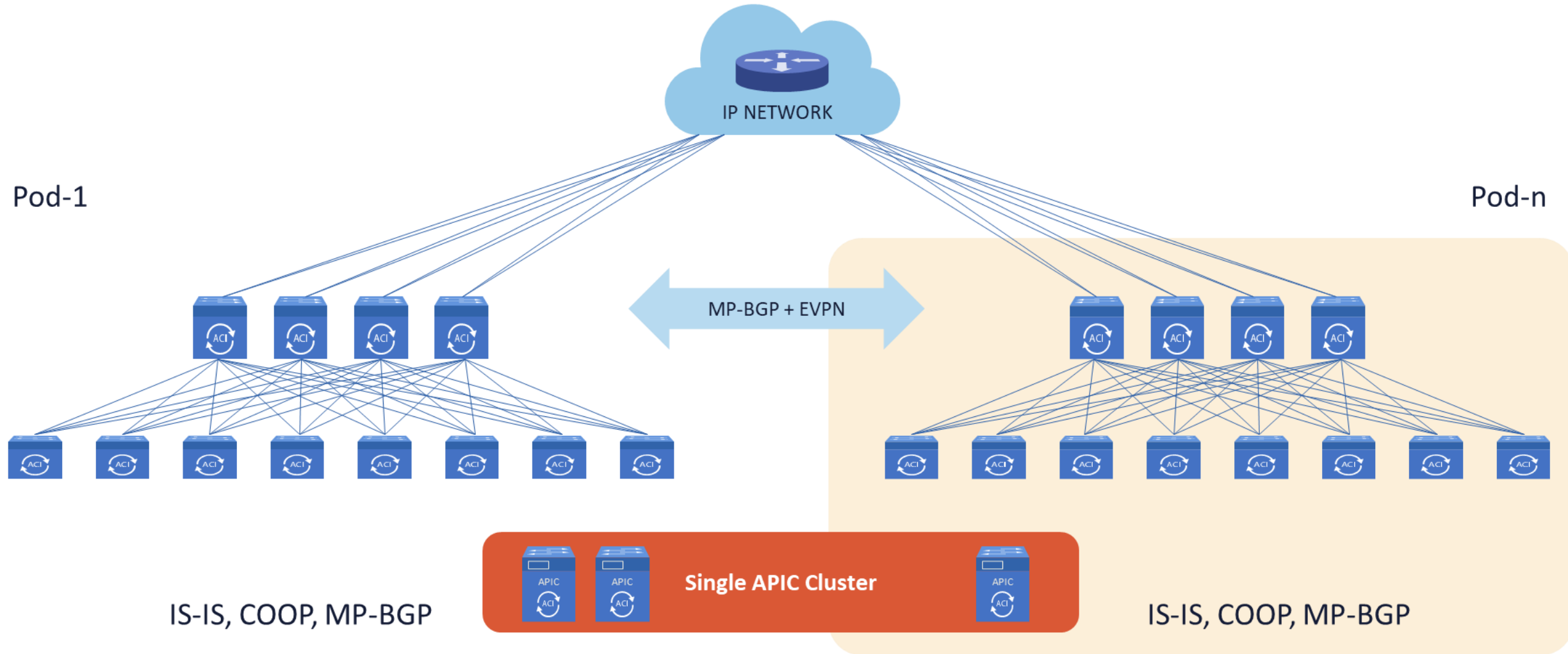
- **Centrally managed:** Network intelligence is (logically) centralized in software-based SDN controllers that maintain a global view of the network, which appears to applications and policy engines as a single, logical switch
- **Open standards-based and vendor-neutral:** When implemented through open standards, SDN simplifies network design and operation because instructions are provided by SDN networking controllers instead of multiple, vendor-specific devices and protocols

Virtual eXtensible LAN (VXLAN)

- VXLAN is technically an encapsulation protocol that offers data center connectivity using tunneling to stretch Layer 2 connections over a Layer 3 network
- VXLAN solutions from a variety of vendors decouple the physical hardware from the network map in order to support virtualization
 - This uncoupling allows the data center network to be deployed programmatically

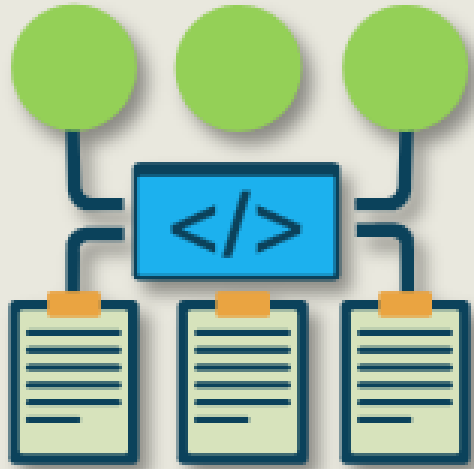


VXLAN (Cisco ACI APIC) Architecture



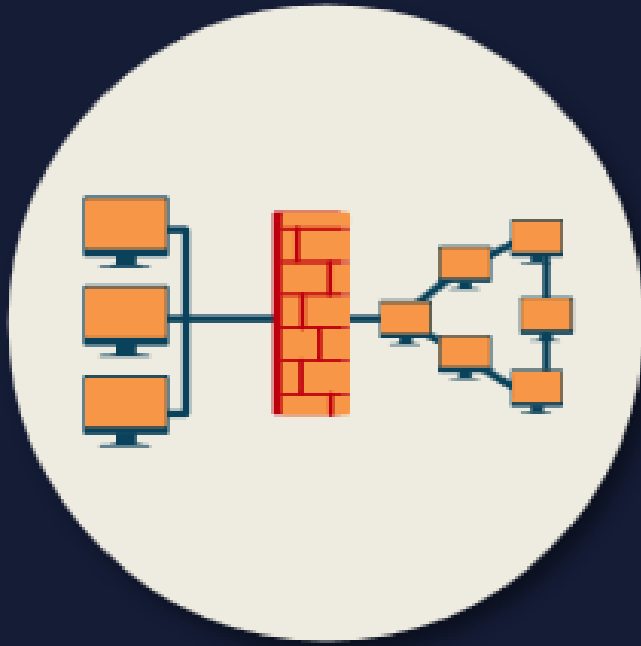
Software-defined Security (SDS)

Used with Software-defined Networks



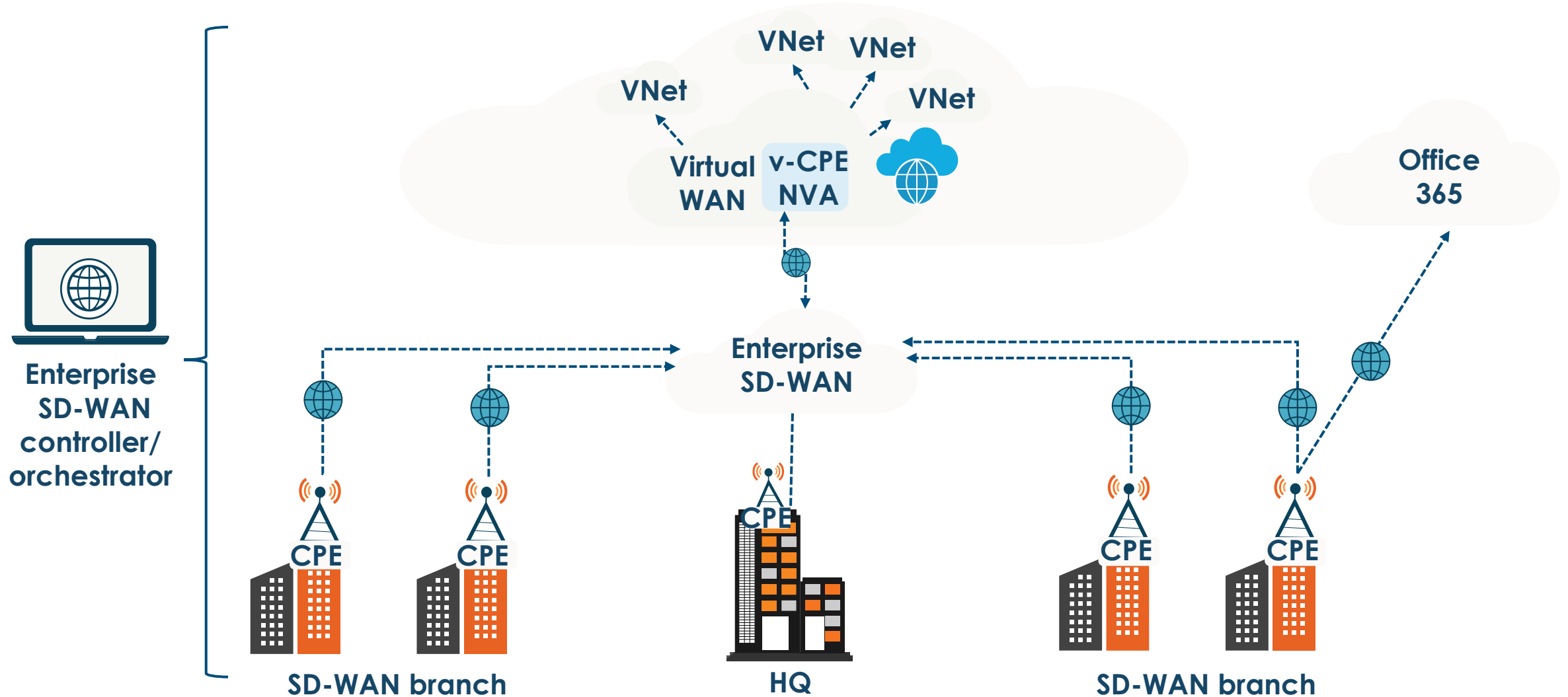
- Software-defined Security (SDS) is a model in which the information security is highly controlled often using virtualization
- The functionality of network security devices, such as next-gen firewalls, intrusion detection and prevention, identity and access controls, and network segmentation are removed from hardware devices to a software layer
- SDS exploits the software-defined networking (SDN) initiative to enhance network security

Software-Defined WAN



- SD-WAN is an SDN approach that raises network traffic management away from the hardware and premises to next-generation software in the cloud for superior agility, control, and visibility
 - It is commonly used with Cloud Providers in metropolitan area solutions
- Incorporates a centralized control function with user-defined application and routing policies to deliver highly secure, robust, application-aware network traffic management

Microsoft Azure SD-WAN Solution



Secure Access Service Edge (SASE)

- SASE is an emerging cybersecurity concept that combines network security functions with SD-WAN and proxy capabilities to deliver a comprehensive, cloud-native service
- SASE is the convergence of wide area networking, or WAN, and network security services like CASB, FWaaS and Zero Trust, into a single, cloud-delivered service model



Software-Defined Perimeter (SDP)

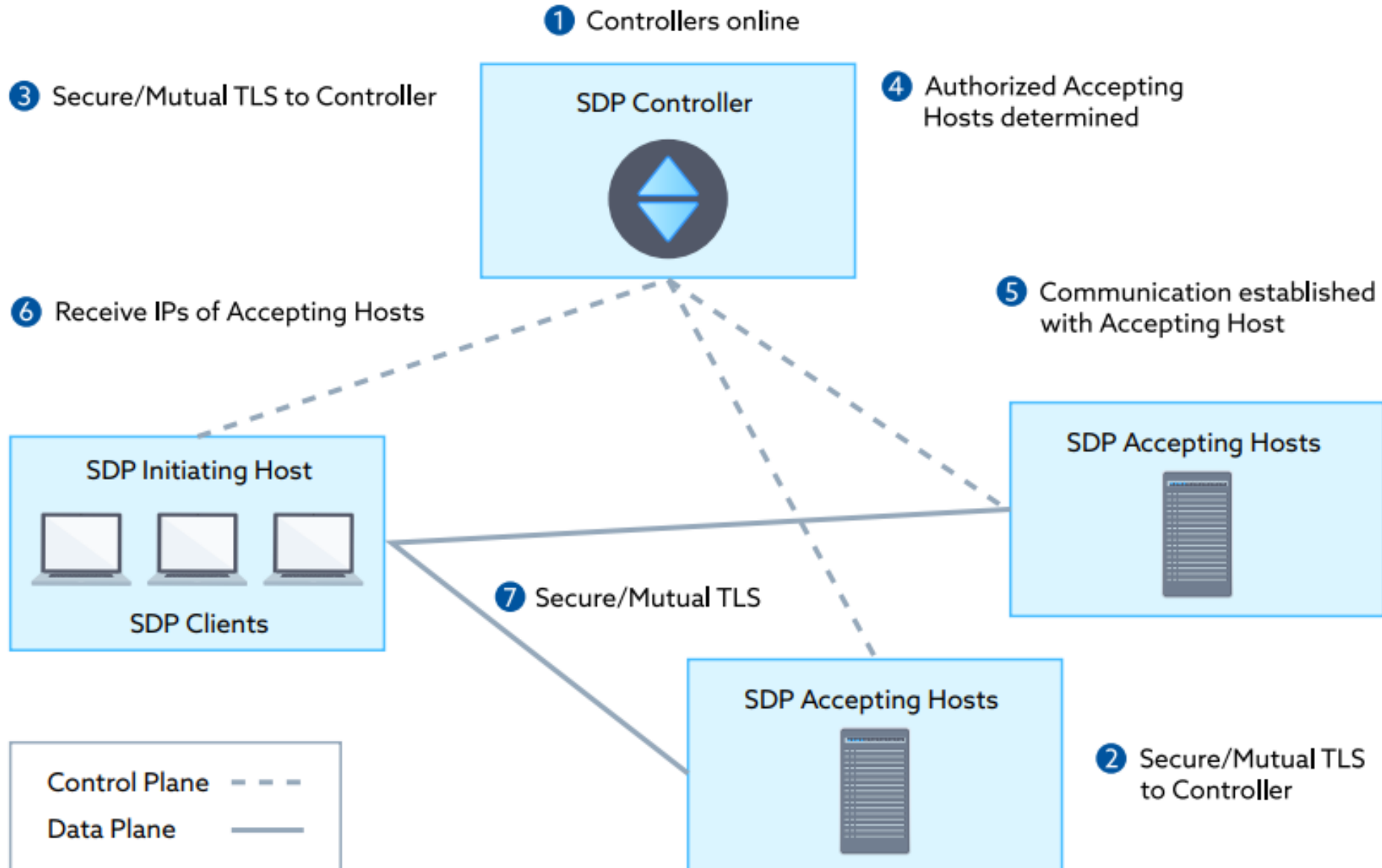
- SDP necessitates endpoints to first authenticate and authorize before getting protected access to IaaS servers and services
- Encrypted connections are generated in real-time between the SDP clients and the application infrastructure
- SDP establishes a secure, "dark" network that is invisible to unauthorized users and devices
- SDP leverages identity-centric controls and micro-segmentation to limit lateral movement



Software-Defined Perimeter (SDP)

- A **Subject** is a user, application, server, service, or device that needs to access a resource object
- **Policy Enforcement Point (PEP)** - example is an 802.1X-compliant switch and/or wireless AP, router, firewall appliance, or cloud virtual load balancer, CDN distribution point, API gateway, etc.)
- **A Policy Decision Point (PDP)** - could be a Cisco Identity Services Engine (ISE), Azure AD, RADIUS/DIAMETER cluster, SAML2.0 IdP, Citrix Secure Private Access
 - The PDP must trust the data it receives (directly or indirectly) and be able to map identity attributes for the identity provider(s)

Software Defined Perimeter (SDP)



- Infrastructure-as-Code (IaC) is a huge enabler for the API of the datacenter and cloud management planes
- IaC is defined in NIST SP 800-172 as “The process of managing and provisioning an organization’s IT infrastructure using machine-readable configuration files, rather than employing physical hardware configuration or interactive configuration tools”
- IaC is the dominant model for deploying cloud resources and is supported by every major provider

Infrastructure-as-Code (IaC)

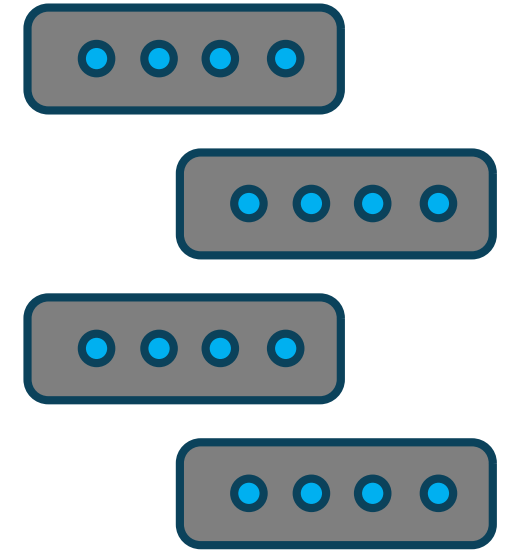


Workload Security Controls

- **Enforcing Controls:** Use lightweight, cloud-aware security agents like EDR
 - Avoid inbound network ports to minimize attack surfaces
- **Monitoring:** Capture workload logs and send them to centralized storage promptly
 - Enrich log entries to account for dynamic workload identities
- **Assessment:** Conduct vulnerability scans on VM and container images before deployment
 - Perform offline runtime assessments and build assessment agents into images
- Utilize **Cloud Workload Protection Platforms (CWPP)**

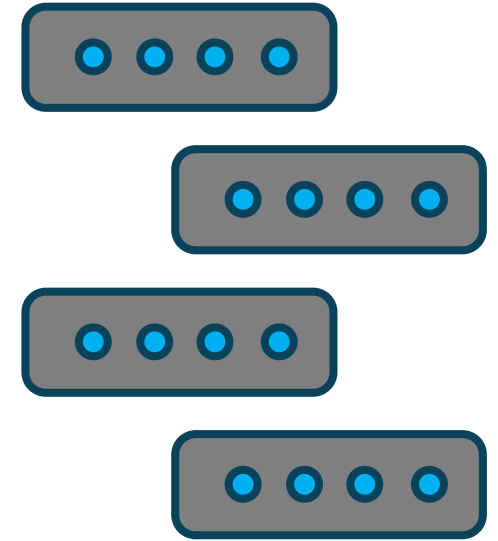
CSA Risks in Virtualized Environments

- Risk #1 – **VM Sprawl, Hopping, and Escape**
- Risk #2 – Sensitive Data Within a VM
 - Passwords, personal data, bash profiles, bash history files, encryption and license keys, images, and snapshots
- Risk #3 – Security of Offline and Dormant VM
- Risk #4 – Security of Golden Image VMs and active VMs
- Risk #5 – Lack of Visibility Into and Controls Over Virtual Networks
 - Traffic over virtual networks may not be visible to security protection devices, such as network-based intrusion detection and prevention systems, on the physical network



CSA Risks in Virtualized Environments

- Risk #6 – Resource Exhaustion
 - **Resource-intensive software tends to exhaust resources in a physical server when it is implemented in multiple VMs.**
 - **For example, anti-virus and other security software interrupt every call to disk or memory**
- Risk #7 – Hypervisor Security (**hyperjacking**)
- Risk #8 – Unauthorized Access to Hypervisor
- Risk #9 – Account or Service Hijacking Through the Self-Service Portal
- Risk #10 – Workload of Different Trust Levels Located on the Same Server
- Risk #11 – Risk Due to Cloud Service Provider API





VM Sprawl Mitigation

- Put effective policies, guidelines, and processes in place to govern and control VM lifecycle management
- Control the creation, storage, and use of VM images with a formal change management process and tools
- Keep a small number of known-good—and timely patched—images of a guest OS separately
- Use virtualization products with management solutions to examine, patch, and apply security configuration changes to VMs



Protecting Sensitive Data within a VM

- Encrypt data stored on virtual and cloud servers and release encryption/decryption keys only to authorized physical or virtual servers
- Develop policies to restrict storage of VM images and snapshots
- Ensure that backup and failover systems, including temporary upgrade/patch instances, are cleaned when deleting and wiping
- Use cryptographic checksum protection to detect unauthorized changes to VM images and snapshots
- Identify critical data files within the VM that may need a higher degree of monitoring



Securing Offline/Dormant VMs and Golden VM

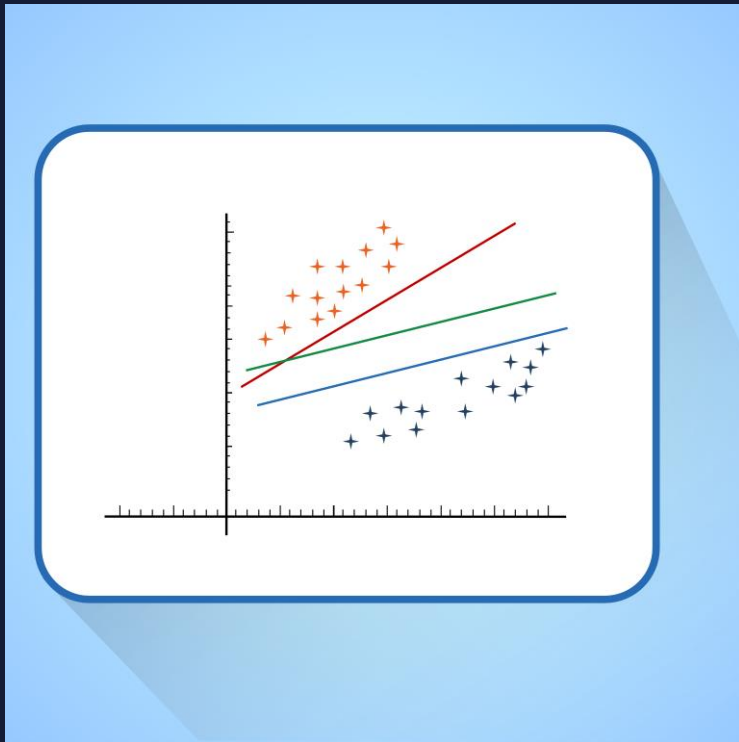
- Ensure proper hardening and protection of VM instances through VM guest hardening
- Augment VM operating systems with built-in security measures, leveraging third-party security technology
- Consider implementing an integrity checksum mechanism for all VM images
- Encrypt VM images to prevent unauthorized modification
- Implement strict controls and processes around access, creation, and deployment of VM images/instances

Gaining Visibility and Controls of Virtual Networks

- Consider a hypervisor that can monitor each guest operating system (introspection) as it is running if separate tools are not installed to monitor communications between VMs
- Implement security technologies that span physical and virtual environments with a consistent policy management and enforcement framework
- Use VM-specific security mechanisms embedded in hypervisor APIs to provide granular monitoring of traffic crossing VM control and data planes such as SDN/OpenFlow



Mitigate Resource Exhaustion



- Implement appropriate resource allocation and/or reservation policies based on classification of VMs
- Use anti-virus and other security software that is virtualization-aware
- Implement mechanisms to minimize resource contention including staggering the scanning of VMs on the same physical server, using agentless deployment of anti-virus software, implementing distributed storage resources, and implementing a workload affinity policy
- Define and implement a standard operating procedure that detects VMs that are throttled due to resource exhaustion

Image Factories

- Image Factories are automated processes and tools for assembling and customizing VM images
- Consider them as the kitchen where the recipe (using the image sources) is followed to create the final VM image
- Image factories ensure consistency and repeatability in the VM creation process with a strong focus on security. T
- Image factories serve as the assembly lines for VM images, where consistency, security, and efficiency are paramount





Container Image Creation

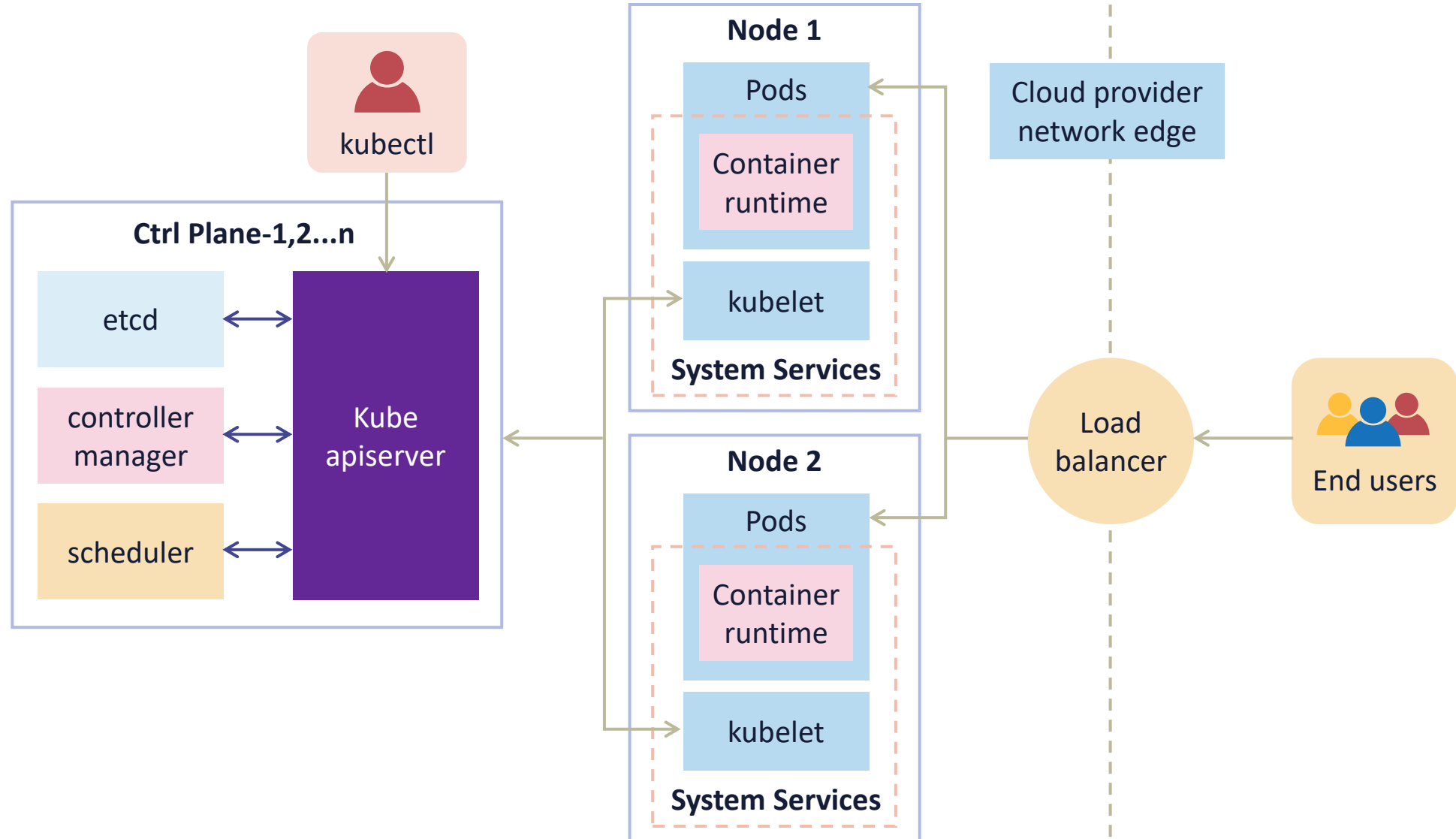
- A container image is a lightweight, executable package that includes everything needed to run an application, such as code, runtime, libraries, and settings
- Created from instructions in a Docker file, it ensures consistency and portability across environments
- Containers should use secure base images and immutable infrastructures, meaning once built and deployed, they are not modified but replaced with new images for updates
- Secure artifact repositories are essential for storing these images safely

Container Orchestration

- Container orchestration is essential for managing containerized applications
- Kubernetes (K8) is renowned for its flexibility and rich features. K8s automates application deployment, scaling, and management across machine clusters, ensuring consistent operation.
- Containers host microservices, maintaining uniform environments for application components.



Basic Kubernetes with Load Balancer and Pods



Securing Container Orchestration Platforms

- Leverage cloud provider tools for security
- Disable unnecessary features, use secure base images, and enforce network policies
- Regularly patch and update all components
- Implement Kubernetes security and network policies
- Follow CIS benchmarks and use standardization tools

Securing Container Orchestration Platforms

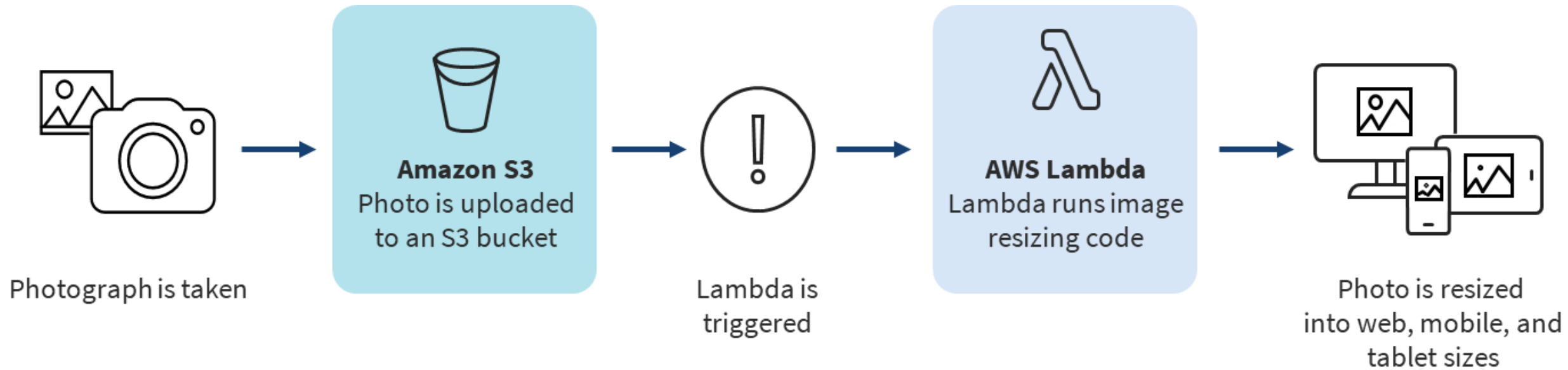
- Use secure and private image repositories with RBAC, image scanning, and signing
- Start with robust, secure configurations and hardened host operating systems
- Encrypt data, use access controls, and monitor access
- Implement segmentation and firewall rules
- Validate and sign images in the CI/CD pipeline



Serverless Computing

- According to the CSA: Serverless computing is a cloud-computing execution model in which the CSP is responsible for allocating compute and infrastructure resources needed to serve Application Owners' workloads
- An Application Owner is no longer required to determine and control how many compute resources (and at what size) are allocated to serve their workload at any given time
- It can rely on an abundance of computing resources that will be available to serve the workload on-demand

AWS Lambda Functions



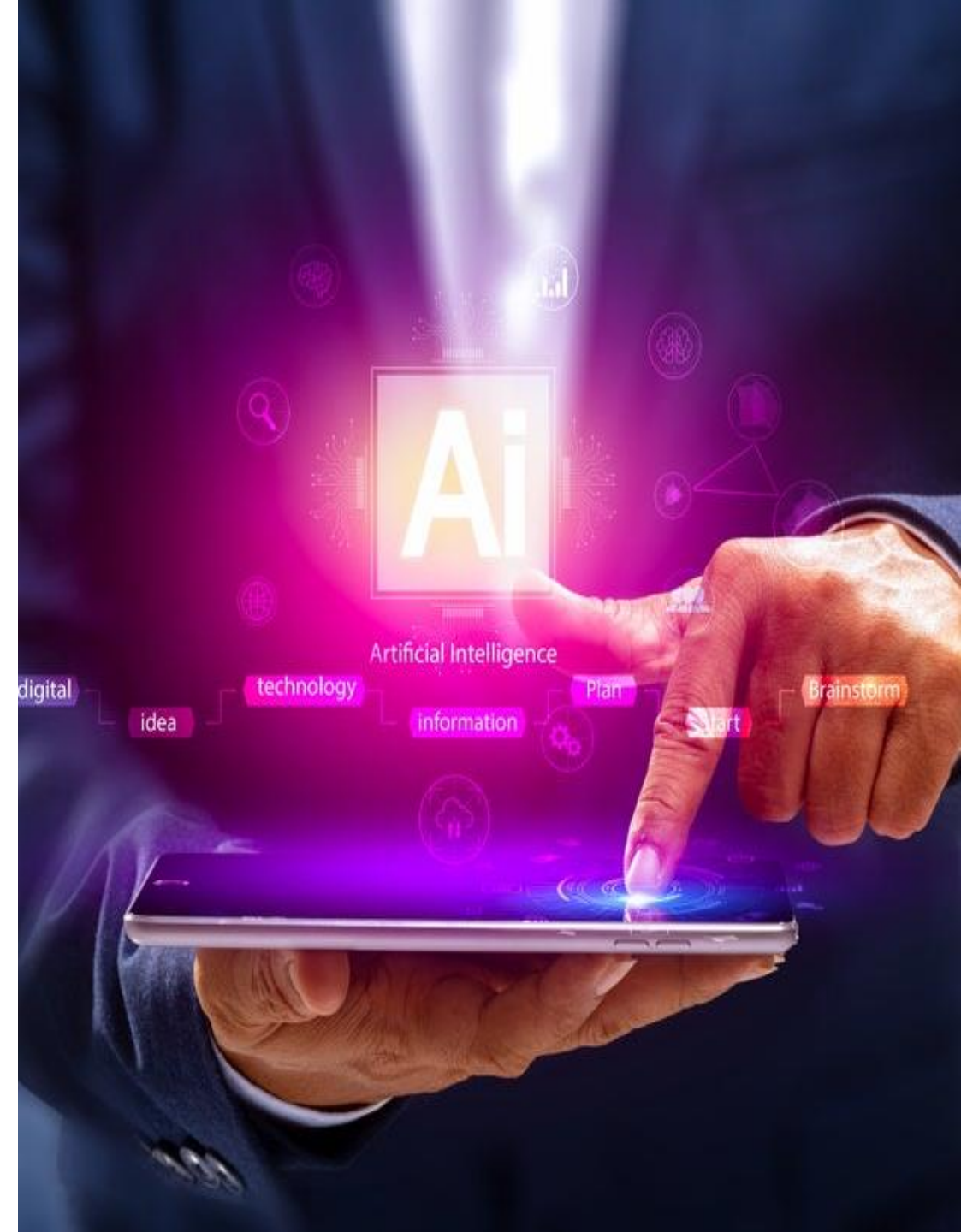
FaaS Security

- Third-party services and APIs: Increased attack surface if compromised
- Vulnerable dependencies: External libraries can harbor risks if not updated
- Misconfigurations: Overly permissive settings can expose sensitive resources
- **Overly-privileged IAM: Excessive permissions heighten breach risks**
- Direct Internet access: Functions exposed to external threats and data exfiltration



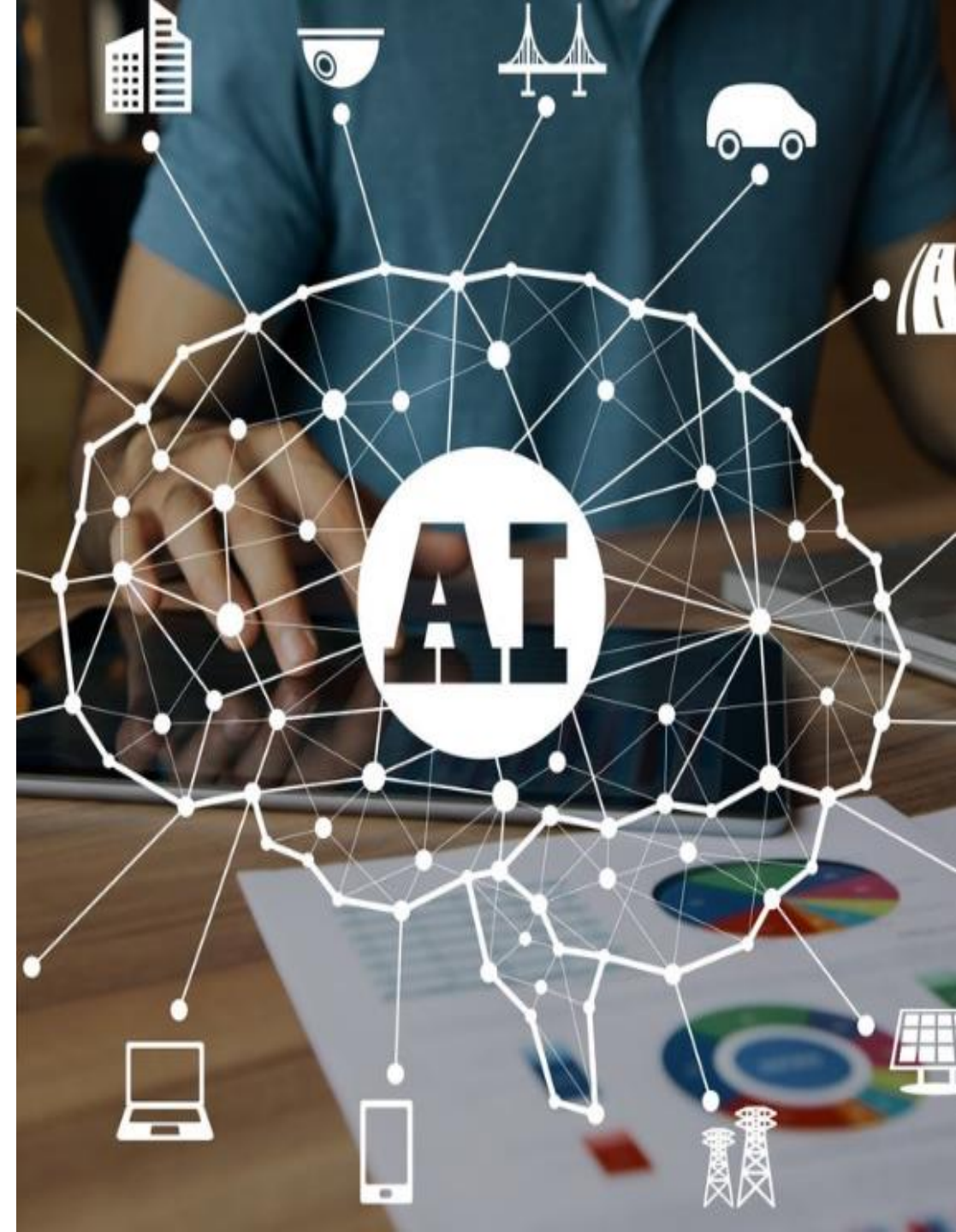
Securing AI Workloads

- AI workloads benefit the cloud environment dynamic scaling capabilities.
- AI helps industries automate tasks, enhance customer experiences and solve complex problems
- Understanding and managing AI workloads is crucial for maximizing AI's potential, with a focus on data, algorithms, and real-time processing to foster innovation

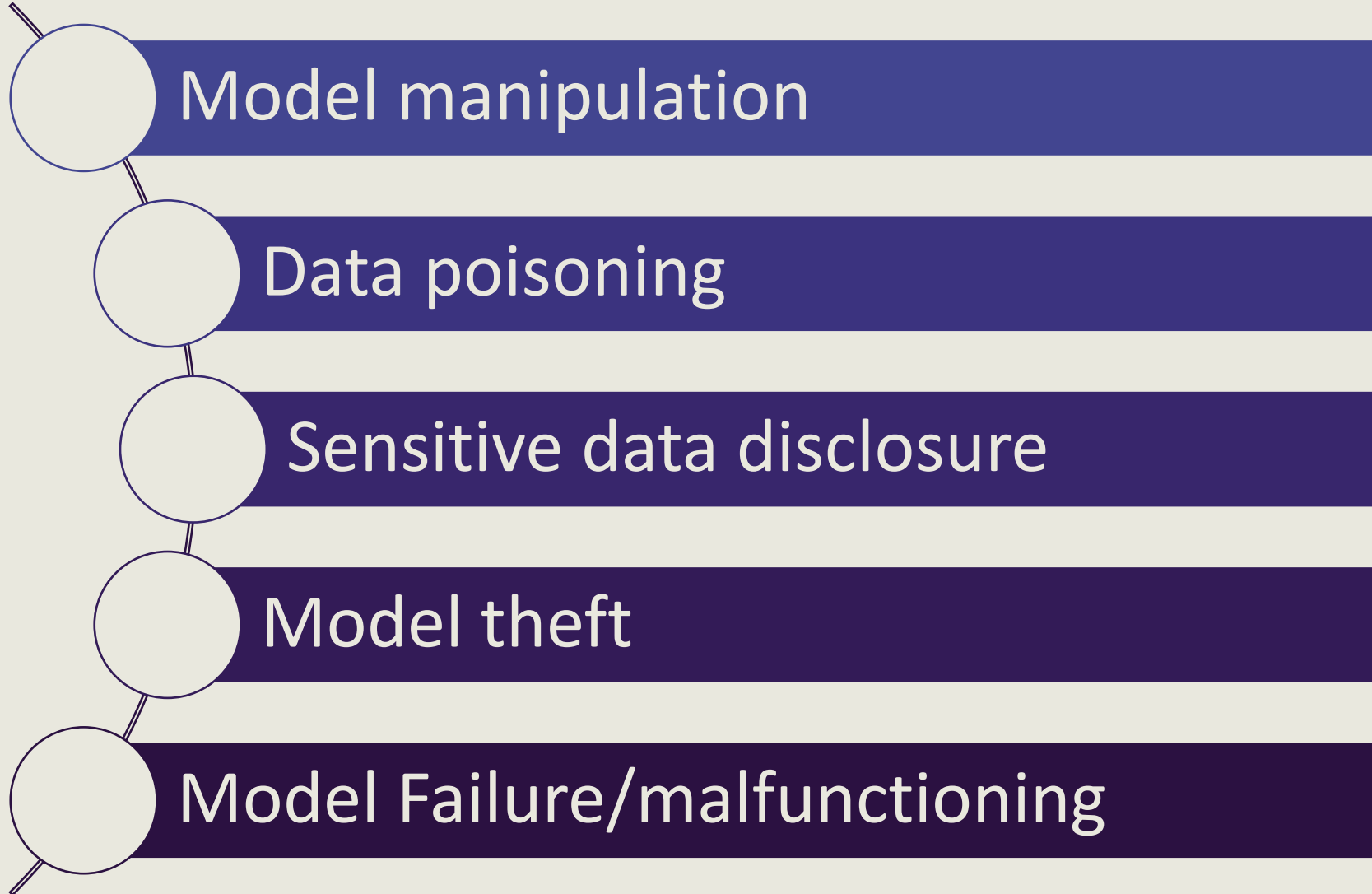


The CSA LLM Threats Taxonomy

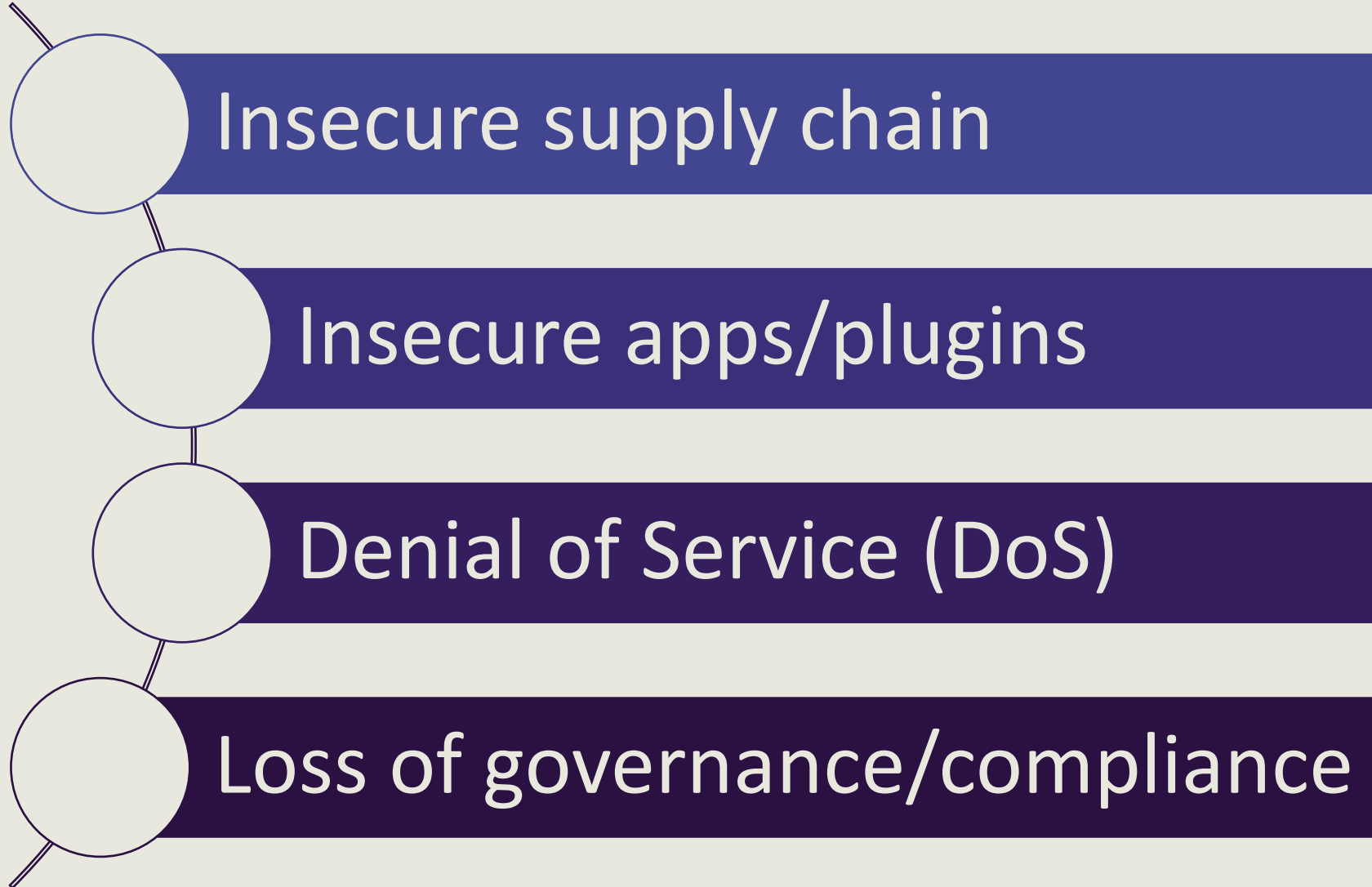
- CSA has developed the CSA Large Language Model (LLM) Threats Taxonomy, which establishes a common taxonomy and definitions for key terms related to risk scenarios and threats to LLMs
- The goal is to provide a shared language and conceptual framework to facilitate communication and alignment within the Industry.
- The document defines the following risk categories



The CSA LLM Threats Taxonomy



The CSA LLM Threats Taxonomy



A futuristic graphic on the left side of the slide. It features a glowing blue 'AI' icon inside a square frame, surrounded by a network of nodes and lines. Below the icon is a stylized brain shape composed of a mesh of points. The background is dark with various digital elements like charts, graphs, and a hand interacting with a laptop keyboard. A bright pink diagonal bar separates this graphic from the text on the right.

AI Data Security

- **Encryption:** Protect data confidentiality during transmission and storage
- **Differential privacy:** Introduce randomness into data or queries so that individual records can't be traced back to a person. It's like adding noise to a conversation to mask private details
- **Secure multi-party computation:** Process data from multiple sources without exposing sensitive information by anonymizing or tokenizing sensitive information as part of the flows
- **Confidential computing:** Use Trusted Execution Environments (TEEs) to safeguard data during processing and protect AI model execution



AI Model Security

- **Model hardening:** Defend against adversarial attacks to enhance model resilience
- **Robust training:** Employ techniques to improve generalizability and reduce overfitting
- **Adversarial training:** Strengthen AI models against attacks by incorporating manipulated examples into their training data and enhancing resilience
- **Model watermarking:** Embed unique identifiers to assert ownership and deter theft
- **Output manipulation:** Altering the AI's responses to obscure its decision-making process can thwart potential thieves (much like a poker player's bluff)



AI Infrastructure Security

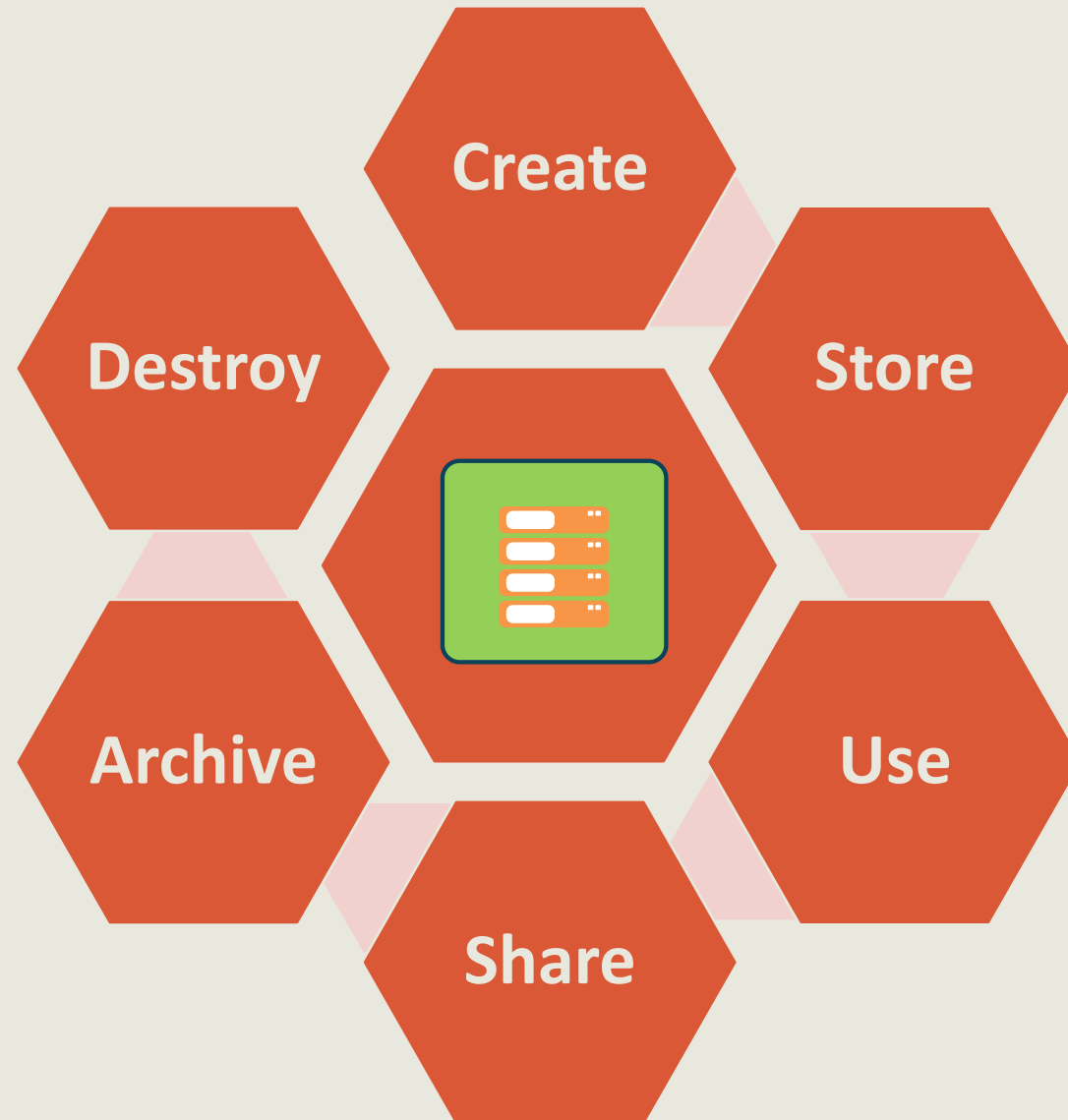
- **GPUs and TPUs:** To maintain system integrity, utilize hardware-based security features, regular firmware updates, and network security measures
- **AI services:** Follow best practices for cloud services, including access controls and real-time monitoring
- **Quotas and rate limiting:** Apply quotas and rate limiting to identify and prevent DoS and distributed denial-of-service (DDoS) attacks

A graphic on the left side of the slide featuring a hand typing on a laptop keyboard. Overlaid on the keyboard is a glowing blue network diagram with a central square icon containing the letters 'AI'. The background is dark with blue and green light effects.

AI Supply Chain Security

- **Policies:** Define and approve a cybersecurity policy for the supply chain
- **Software supply chain risk management:** Regularly audit and update third-party dependencies
- **Vetting third-party services:** Conduct security assessments before integration
- **Trusted sources:** Rely on reputable sources for software dependencies, maintaining an approved list

Cloud Secure Data Lifecycle



Cloud Data Life Cycle

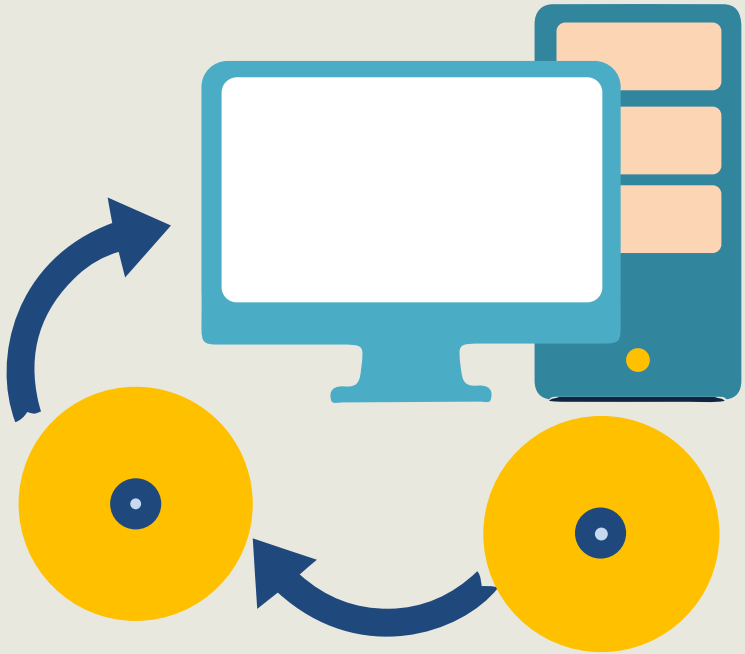
Phase 1: Create



- Data is either generated, inputted, or modified into another format either locally or in the cloud
- The data owner is identified in the create phase
- Other key activities of phase one include:
 - Data discovery
 - Data categorization
 - Data classification
 - Data mapping
 - Data labeling (tagging)

Cloud Data Life Cycle

Phase 2: Store



- After the Create phase, the data is put into a volume (block)/object storage system or into one of several types of database systems
- This phase relates to transactional, near-term usage data as **opposed to long-term cold data storage**
- It also includes files and spreadsheets, typically done at during or at the end of the Create phase
- **Activities of this phase can also occur simultaneously when the data is generated in phase one**

Cloud Data Life Cycle

Phase 3: Use



- Data is utilized by people, applications, and tools as well as being changed from the original state
- Raw data becomes information
- The systems that “use” the data must be secured as well; for example, endpoint detection and response (EDR)
- Technologies like VPN, Identity Rights Management (IRM), and Data Loss Prevention (DLP) engines may be introduced
- Assistance can come from a Managed Security Service Provider (MSSP) or Cloud Access Security Broker (CASB)

Cloud Data Life Cycle

Phase 4: Share



- Data is visible, analyzed, and apportioned among users, systems, and applications
- Global collaboration and sharing of data introduces obvious risks and lack of control
- Most of the control used in the previous phases will be implemented here in phase four (such as IRM and DLP services)
- Stringent Identity and Access Management (IAM) and/or Identity Management (IdM) should be used to enforce the least privilege principle in line with access control model (DAC, RBAC, MAC, ABAC, etc.)

Cloud Data Life Cycle

Phase 5: Archive



- Data is stored for long-term and removed from active usage
- It can be sanitized based on policy
- Stringent cryptography will be introduced for data at rest – as in AES-GCM-256 AEAD solutions
- Archiving is often automated and based on governance or
- Factors in choosing long-term storage:
 - Location
 - Media format
 - Staffing
 - Operating procedures

Cloud Data Life Cycle

Phase 6: Destroy

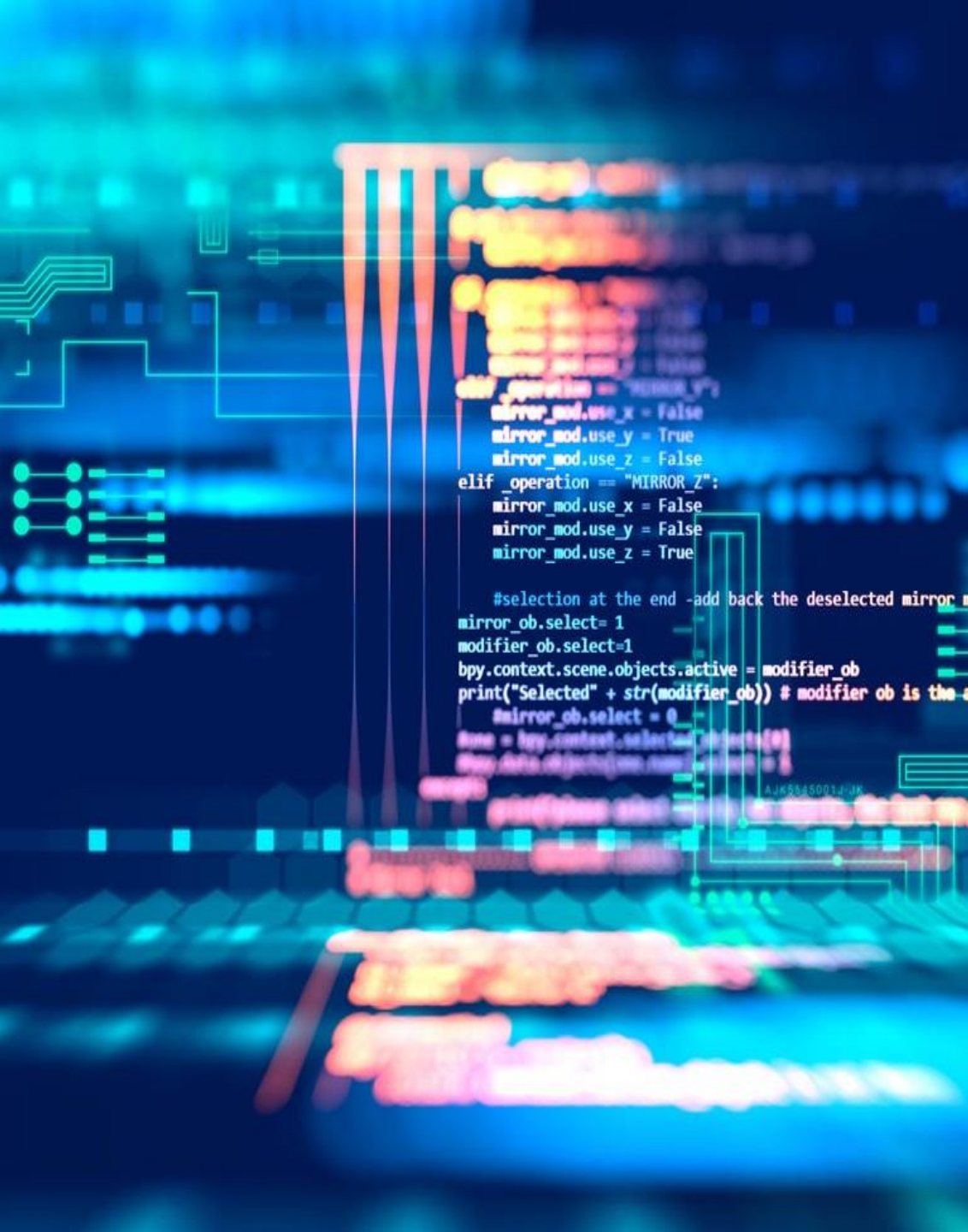


- Data is no longer accessible or usable based on lifetime, utility, policy, governance, and/or regulations
- **Although data can be disposed of using a variety of methods, when storing data at a CSP, cryptoshredding (cryptographic erasure) is the only practical and comprehensive solution**
- The provider will have their own established methods for disposal of data and media, often using military grade programs or physical destruction

Data Security

- Data security is vital for organizational integrity, confidentiality, and customer trust, as well as regulatory compliance
- With cloud services expanding rapidly and cyber threats growing more sophisticated, a robust approach to safeguarding information is imperative





Data Security Posture Management (DSPM)

- DSPM is an emerging category of tools designed to focus on data-centered security.
- It includes data discovery and classification, which may also include DLP-like capabilities, to help you understand where you have data and its sensitivity.
- DSPM tools can then pull and evaluate all the overlapping access controls, IAM policies, resources, and network policies to assess and visualize WHO has access to the data and how.

Data Security Posture Management (DSPM)

- These tools offer suggestions and/or directly manage remediation or provide specific recommendations e.g., infrastructure as code (IaC) templates or policies
- The challenge in cloud data security is handling all the potential overlapping controls, all managed in different areas, that don't necessarily provide a complete view of your data use and exposure.
- DSPM is designed to fill that gap



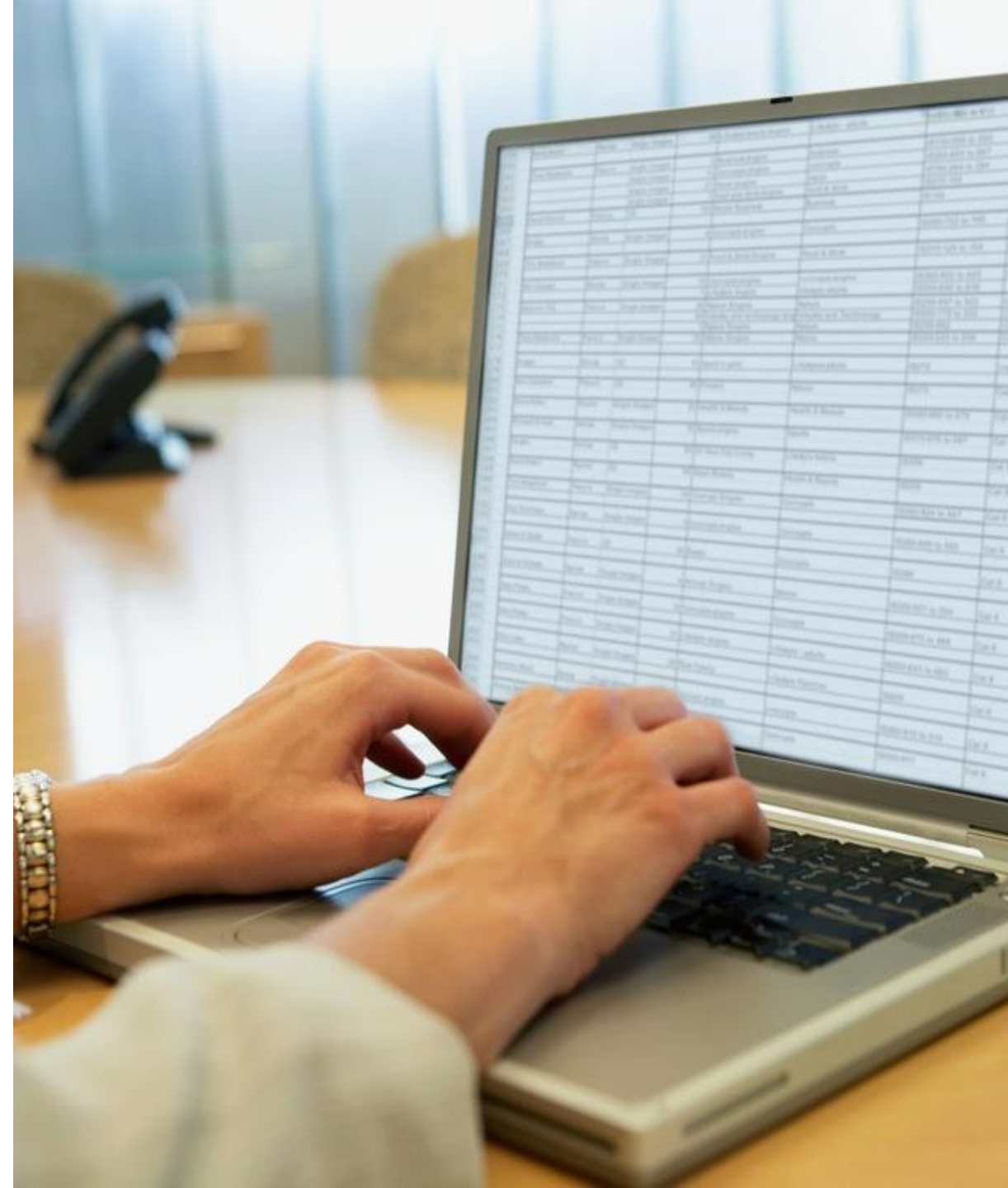


Cloud Data Loss Prevention

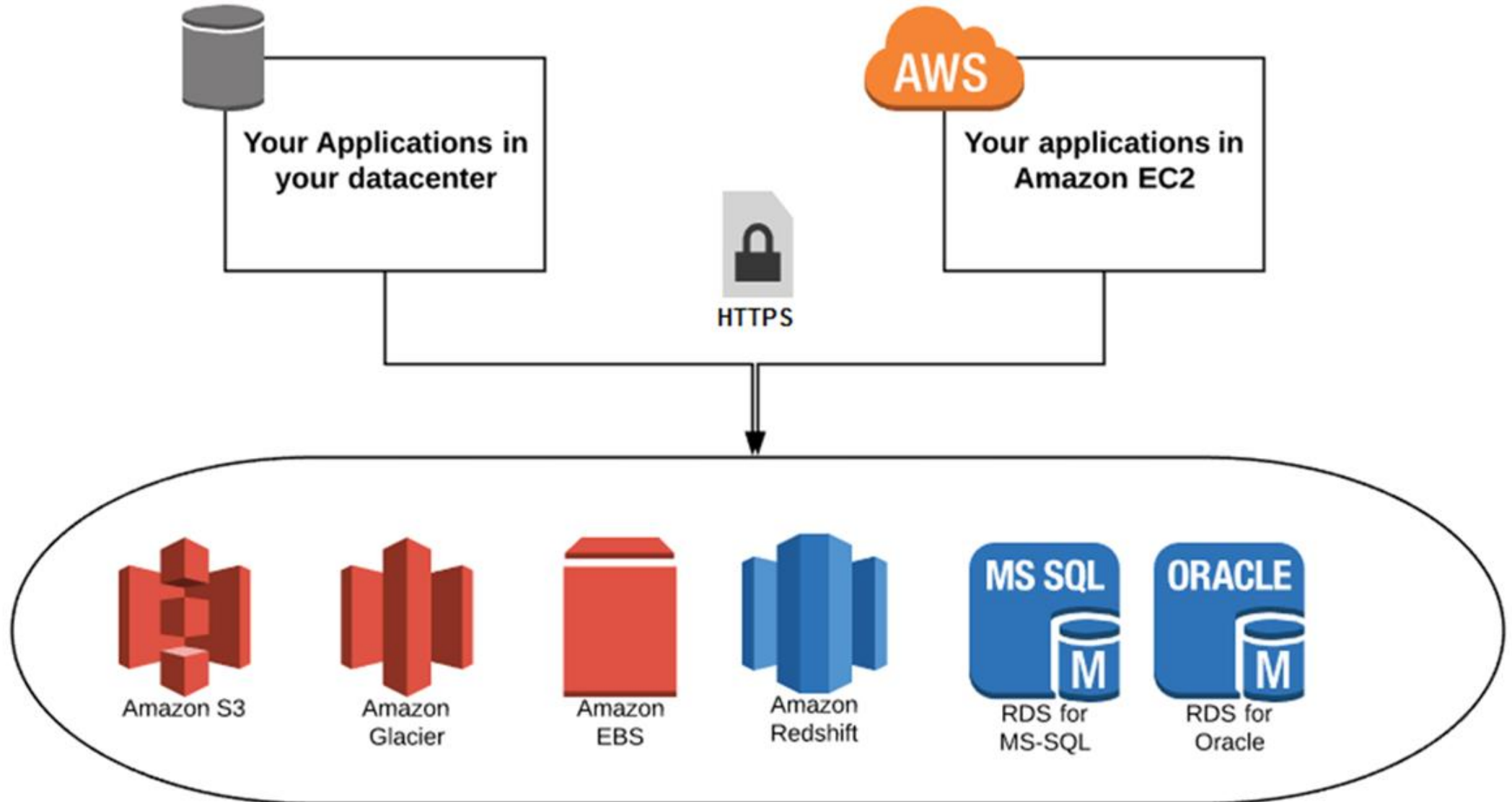
- Data Loss Prevention (DLP) ensures critical data like Intellectual Property (IP) and customer information stays within the organization
- It identifies, monitors, and protects sensitive data, including in the cloud, by discovering, classifying, and enforcing security policies to prevent unauthorized sharing or exfiltration.
- Cloud DLP faces challenges due to the vast data scale and distributed nature of the cloud, making comprehensive scanning difficult, especially for IaaS or PaaS.

Cloud Data Loss Prevention

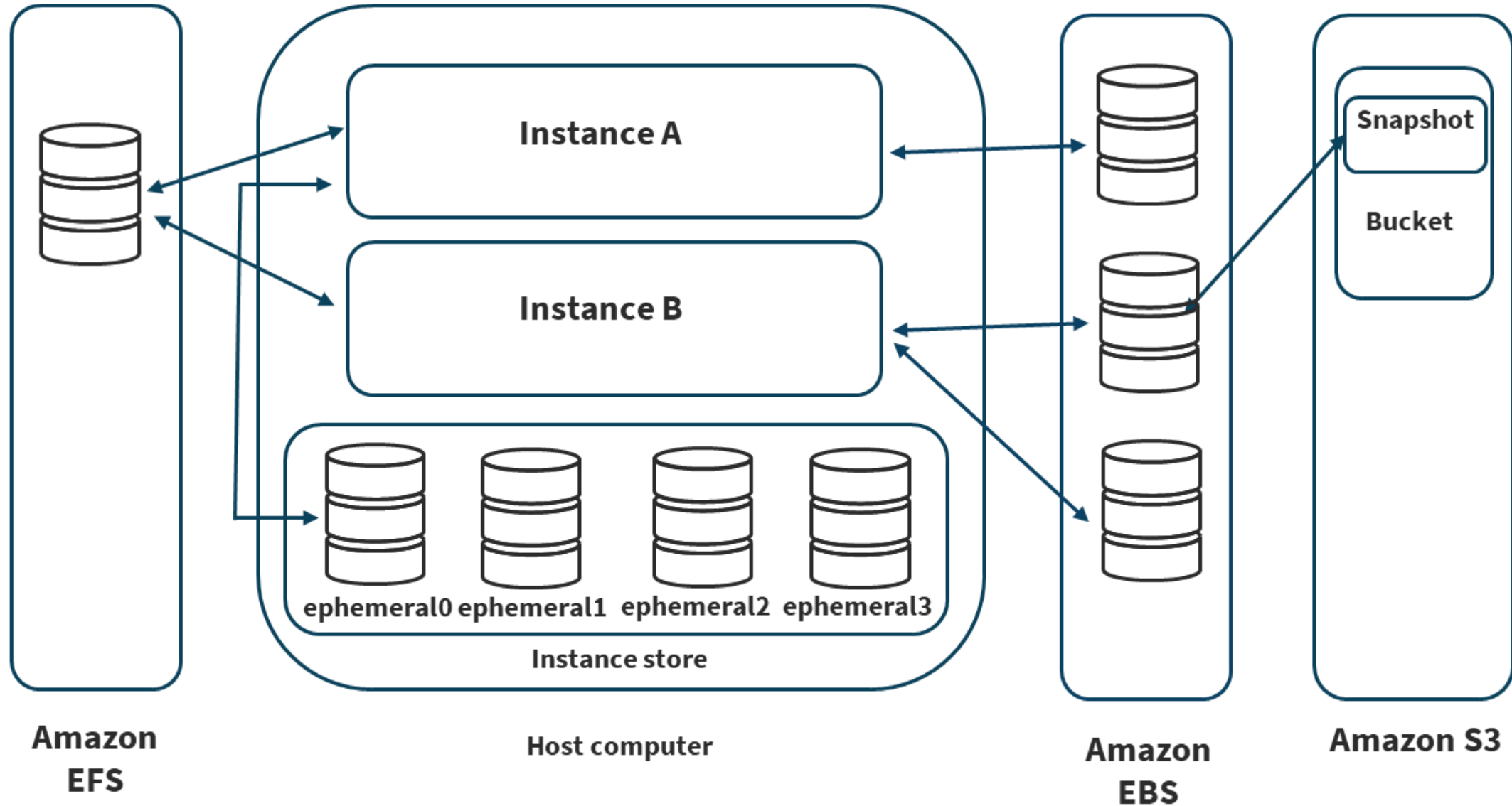
- An effective cloud DLP strategy involves assessing the data landscape, prioritizing high-risk areas, and balancing cloud-native and third-party DLP solutions.
- A risk-based approach, alongside data minimization and robust access controls, helps manage cloud DLP challenges while safeguarding sensitive information across the enterprise cloud footprint.



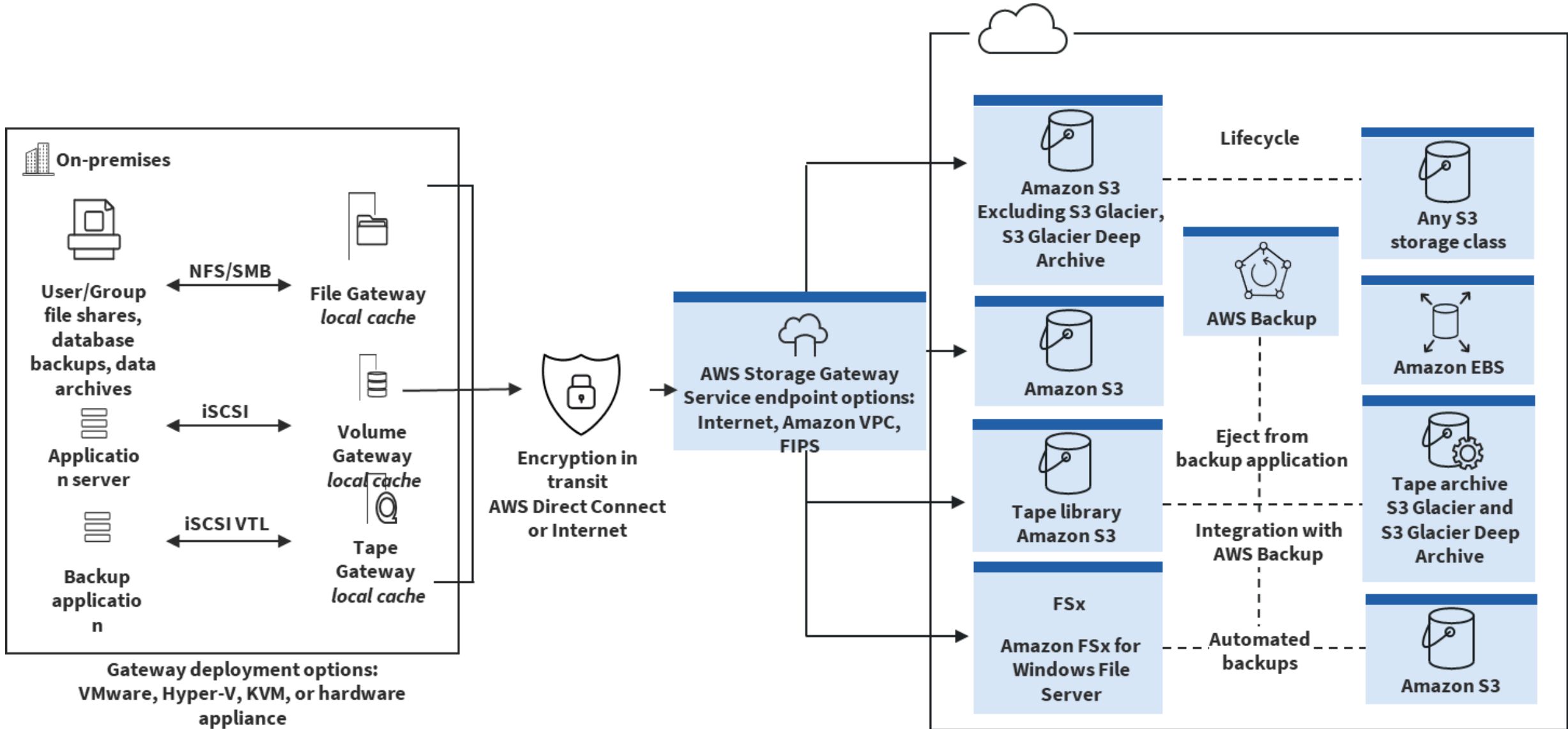
Client-side vs. Server-side Encryption



CSP Storage Options (AWS)



CSP Storage Gateways (AWS)



Data Security for Artificial Intelligence

- As AI technologies become more prevalent and integrated into critical business processes, ensuring the security and integrity of AI systems is paramount
- Data security for AI involves implementing measures to protect AI systems, algorithms, and data assets from various security threats and vulnerabilities

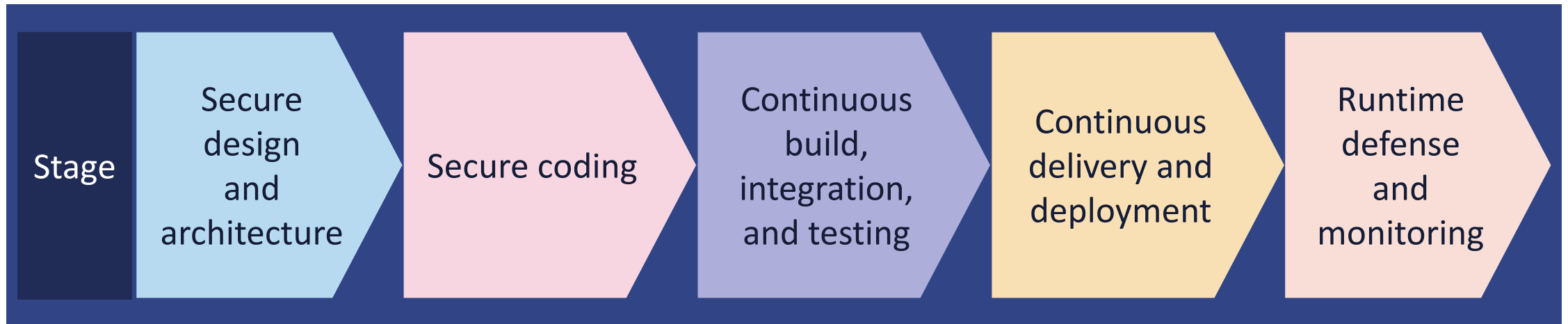


Data Security for Artificial Intelligence

- In the AI as a Service (AlaaS) model, third-party providers offer AI capabilities through subscriptions, allowing organizations to integrate AI into their applications. Key considerations include:
 - Clarifying data-deletion and retention policies
 - Understanding data flow from company assets to services
 - Evaluating the provider's AI security measures against adversarial attacks
 - Understanding Service Level Agreements (SLAs), security practices, and regulatory compliance



Secure Software Development Lifecycle (SSDLC)



Secure Design and Architecture

- The design section references the technologies and tools that can be applied during the design of a product
- We recognize that design is continuous, so new product features and changes will route through design activities
- Without including security in the design phase, security measures will be introduced with a higher operating impact and cost at deployment or runtime



Secure Coding

- Coding security controls that rely on automation as tools can better and more consistently identify weaknesses and vulnerabilities in code compared to manual human reviews
- Without including security in the coding phase, there is a risk that vulnerabilities in source code will be unidentified and deployed into production environments.
- Security vulnerabilities and weaknesses will be more expensive to fix later in the SSDLC

Continuous Build, Integration, and Testing

- Integration and testing include the tools and processes to security test the functionality of an application/product.
- Without the tools and methods, security vulnerabilities and weaknesses will be the source of exploitation and result in data breaches and availability issues





Continuous Delivery and Deployment

- Pre-deployment safety checks ensure that an application/product is deployed onto secure infrastructure.
- Without including security in deployment, there is a risk that vulnerabilities and poor security practices weaken an application or product, exploiting it for attacks in production environments



Runtime Defense and Monitoring

- The capabilities and practices that can be applied after an application/product has been released into production.
- Runtime security enables continuous improvement by identifying inefficiencies, vulnerabilities, and weaknesses and enabling incident response

Threat Modeling



- Threat modeling is a structured process used in risk management to identify, assess, and address potential security threats to an organization's assets.
- In SDLC, this process is used in the context of application risks. It involves understanding the system architecture, identifying security objectives, and analyzing the potential threats that could affect those objectives.
- This process helps create a more secure system design by focusing attention on areas more vulnerable to attacks

STRIDE

Threat	Definition	Property	Example
Spoofing	Pretending to be someone else	Authentication	Hack victim's email and to send messages as the victim
Tampering	Changing data or code	Integrity	Software executive file is tampered with by hackers
Repudiation	Claiming not to do a particular action	Non-repudiation	"I have not sent an email to users"
Information Disclosure	Leaking sensitive information	Confidentially	Making credit card information available on the internet
Denial of Service	Non-availability of service	Availability	Web application not responding to user requests
Elevation of privilege	Ability to perform unauthorized action	Authorization	Normal user can delete admin account

SAST

Static Application Security Testing (SAST)

- SAST is commonly defined as a **white-box test**, where an analysis of the application source code, byte code, and binaries is carried out by the application test **without executing the code**
- It is used to find coding errors and omissions that are symptomatic of security vulnerabilities
- SAST is often used as a test method when the tool is under development - **earlier in the development lifecycle**
- It can be used to find SQL injection attacks, cross-site scripting errors, buffer overflows, unhandled error conditions, and probable back doors into the application

DAST

Dynamic Application Security Testing (DAST)

- Due to the nature of SAST being a white-box test tool, SAST typically delivers more comprehensive results than those found using DAST
- DAST is considered a black-box test, where the tool must find distinct execution paths in the application being analyzed
- Unlike SAST, which analyzes code that is not running, DAST is used against **applications in their running state**
- It is primarily considered effective when testing exposed HTTP and HTML interfaces of web applications

IAST

Interactive Application Security Testing

- IAST combines the advantages of a SAST and a DAST solution
 - The benefits of a static view, because they can see the source code
 - The benefits of a web scanner approach, since they see the execution flow of the application during runtime
- It can detect ~100% of OWASP benchmark in real-time with no false positives
- IAST is flexibly be used in QA and production environments, analyzing dependencies as well as legacy components
- Continuous detection – DevOps-friendly

Software Composition Analysis (SCA)

- SCA involves auditing the external open-source components your software relies on, such as libraries and system components
- This method ensures these components are current and free from known vulnerabilities, and the type of license of these components helps avoid bringing licensing risks into the project.
- SCA can also assist in creating a Software Bill of Materials (SBOM) which is required by certain standards, providing transparency on all components used in the software





Secrets Management

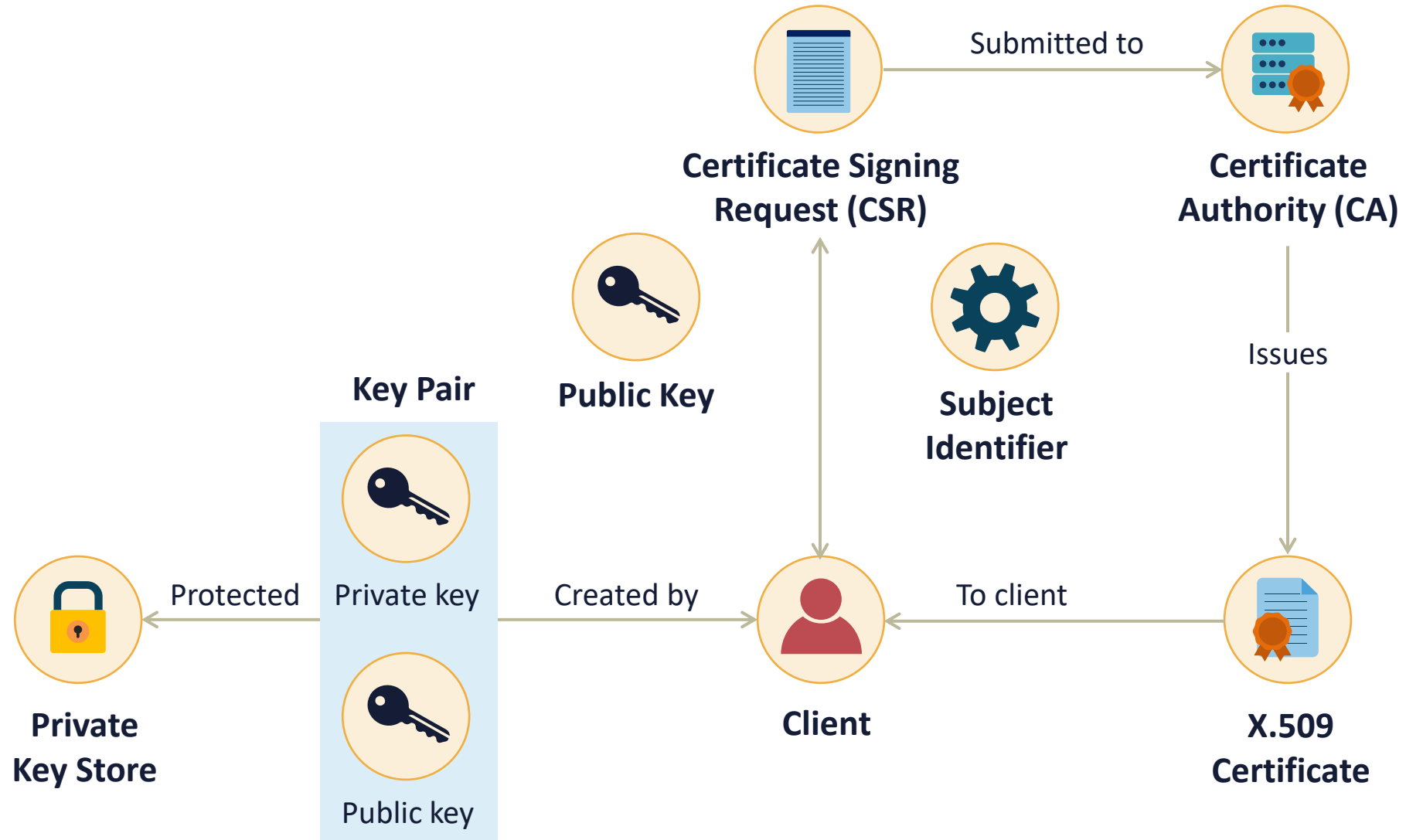
- Secrets are digital authentication credentials, such as passwords, keys, and tokens, that are used by applications or infrastructure services to communicate between them or with other services
- Effective secrets management ensures these sensitive elements are stored, accessed, and managed securely, preventing unauthorized access, and mitigating the risk of data breaches
- It involves tools and policies to create, distribute, rotate, and revoke access credentials systematically, along with secret leak detections, thus safeguarding the integrity and confidentiality of data across the infrastructure



Secrets Management

- Most of the cloud providers today offer alternatives to static secrets
- Depending on the deployment scenario, secrets can be avoided by assigning IAM roles/identities to services
- For scenarios where secrets must be used, all IaaS/PaaS providers offer secure storage services for keeping secrets safe
- These integrate with IAM and eliminate the need to keep secrets in application code, configuration files, or other insecure storage

Secrets Management

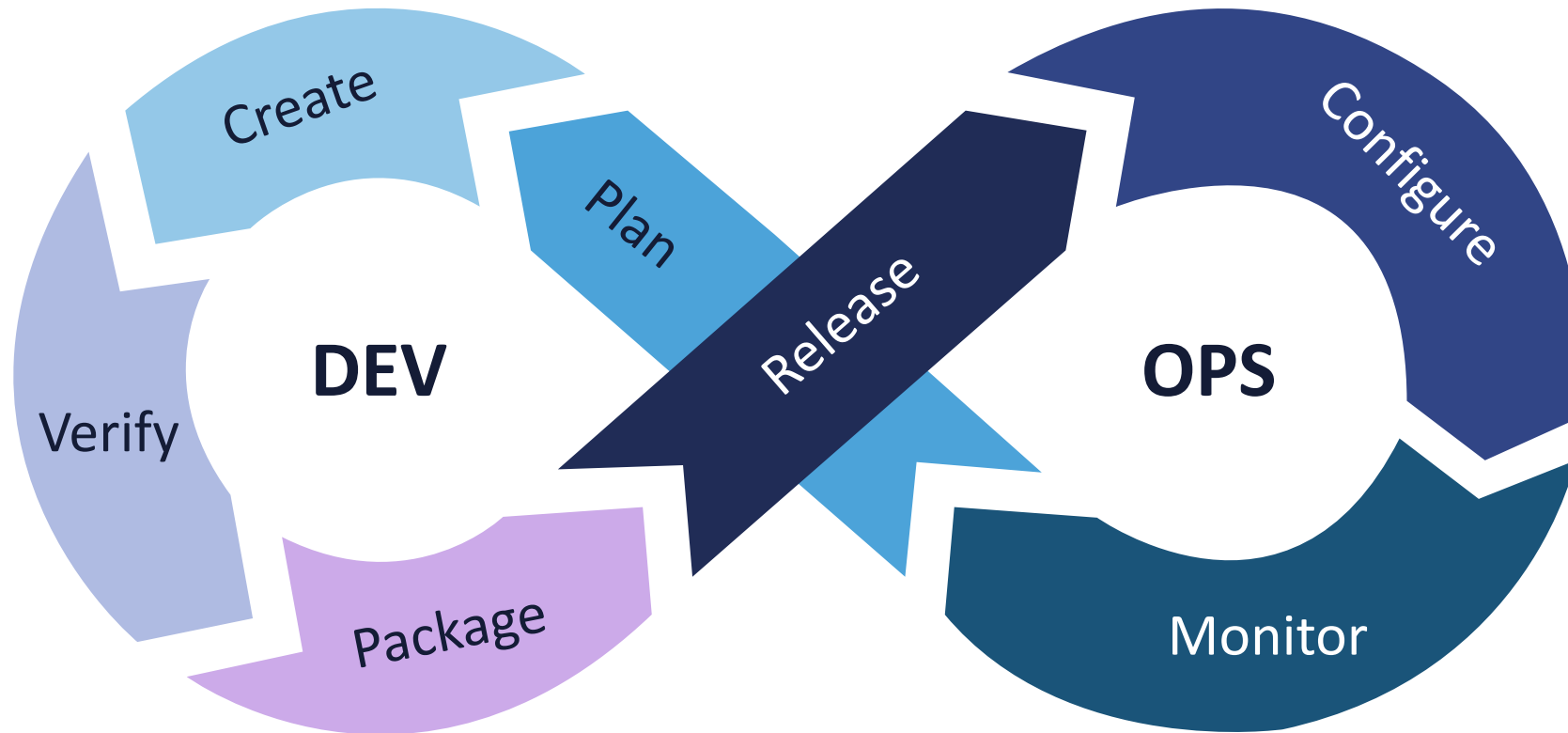


DevSecOps

- This is a clipped compound referring to a set of practices that accentuate the collaboration and communication of both software developers and IT professionals that automate the software delivery process
- DevOps is a methodology for building software quickly by linking development and operations
- DevSecOps involves considering application and infrastructure security from the start and automating some security gates to keep the DevOps workflow from slowing down
- Choosing the right tools to integrate security continuously is critical



DevSecOps CI/CD Lifecycle

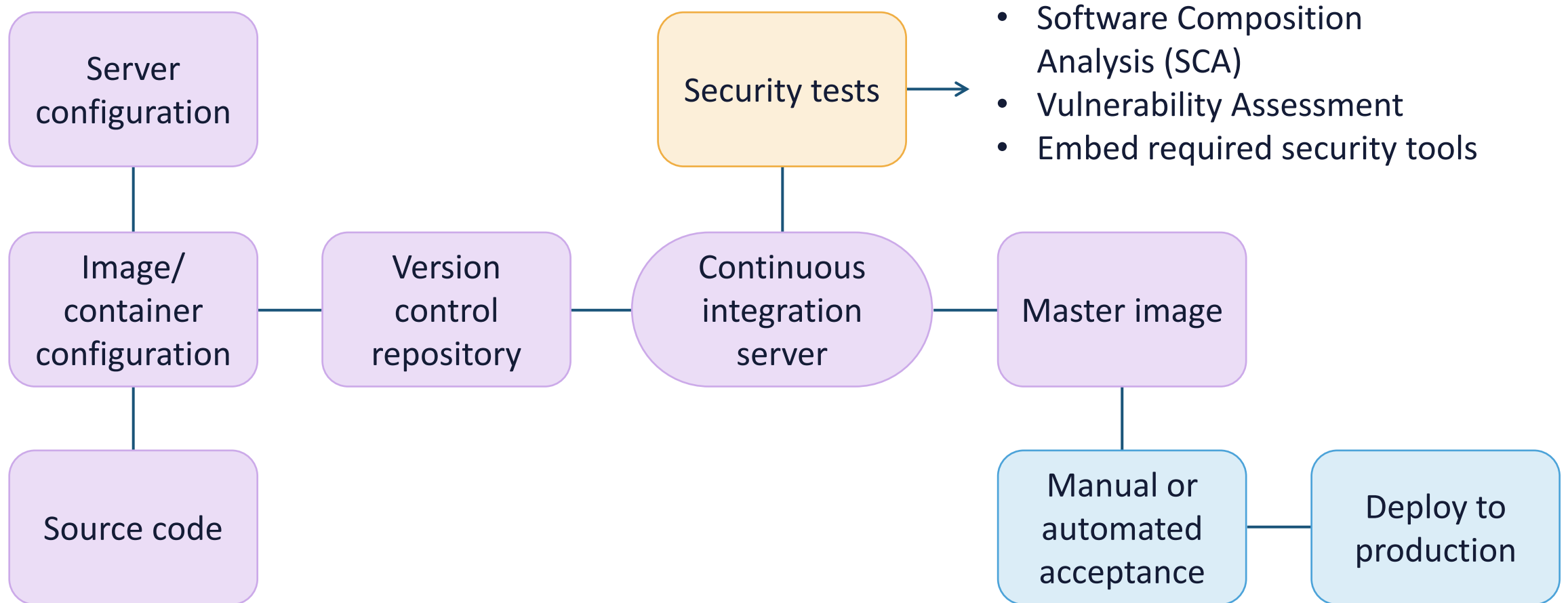


“Shift-Left”

- “Shift Left” is the phrase used to indicate that “security” should move to earlier phases in the SSDLC to ensure secure-by-design and secure-by-default products
- Shift-Left drives proactive security by ensuring each phase of the SSDLC, starting from inception and planning, is viewed through the lens of security
- This approach also serves to be cost-effective compared to “bolting-on security” at a later phase in the SSDLC



Secure Image Deployment Pipeline



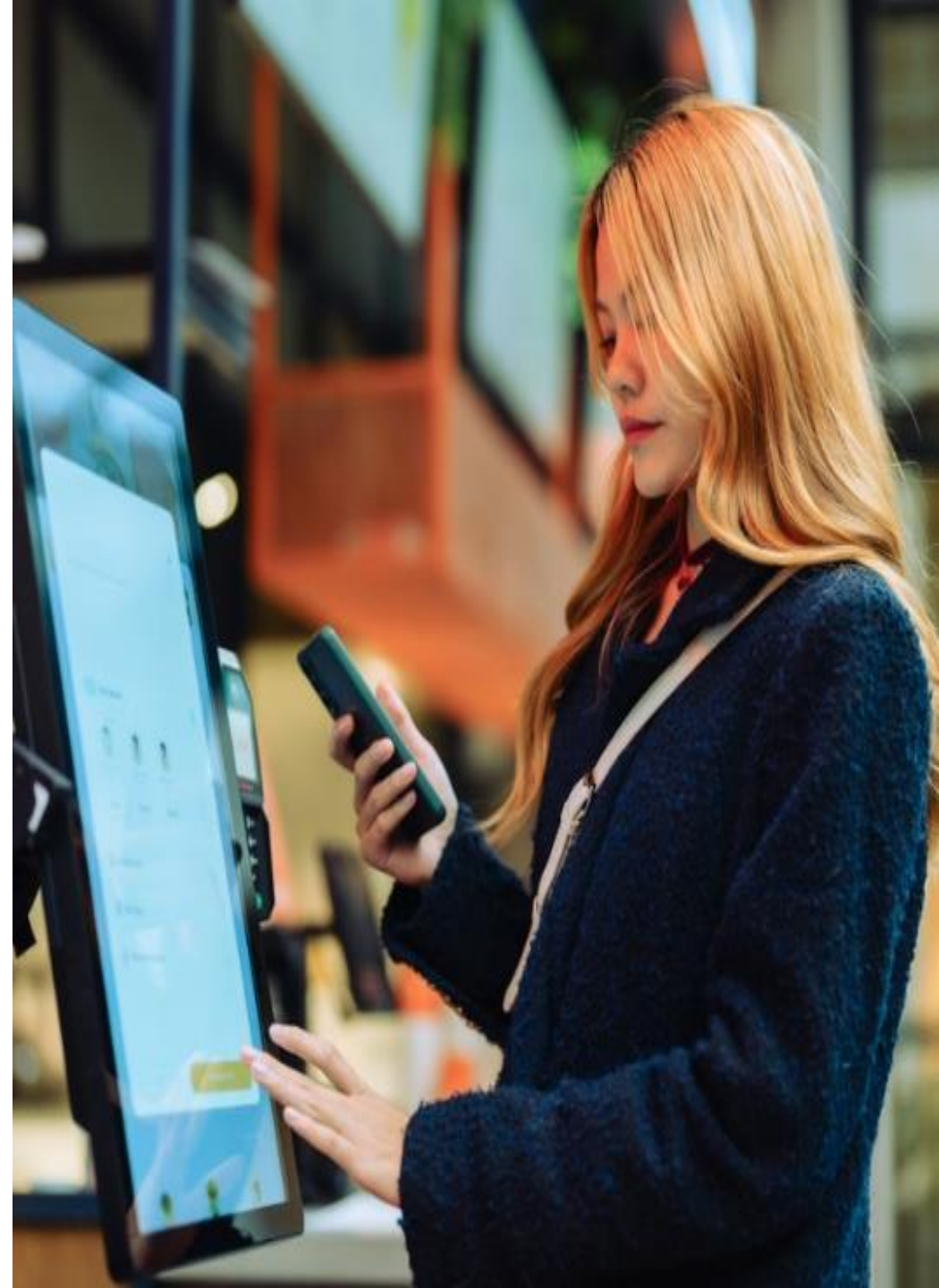


Incident Response

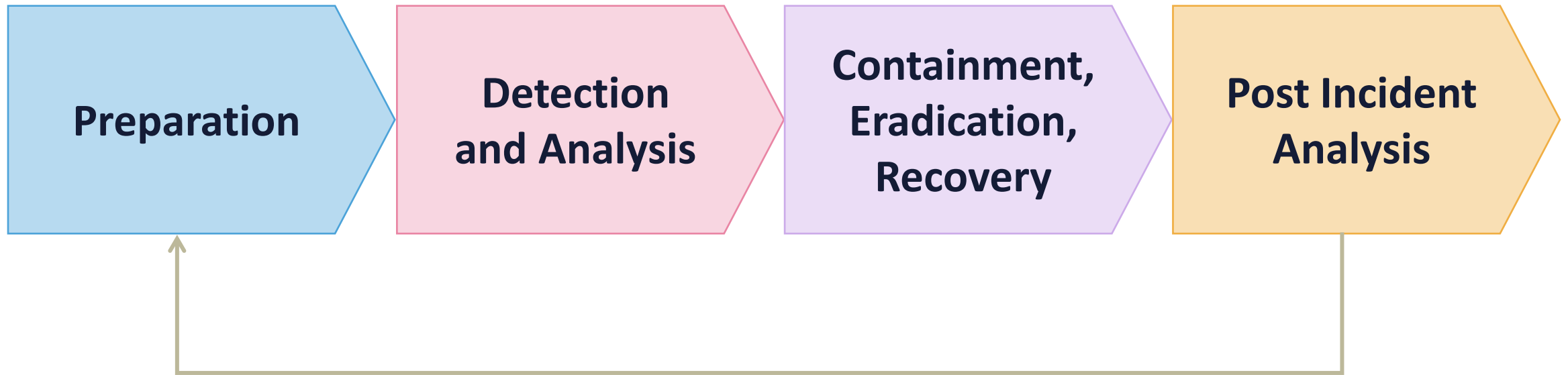
- Cloud IR is about detecting, identifying, and responding to events that could affect a cloud platform, applications, and data
- This necessitates a clear differentiation between events, incidents, and breaches
- Each represents a distinct level of threat and requires tailored response strategies
- An 'event' is any observable issue on a cloud platform that may indicate an underlying security or availability issue

Incident Response

- An event can escalate to an 'incident' when it is determined to violate security policies, unauthorized use or access, or any condition that could threaten operations or the cloud environment
- Incidents require immediate attention to contain and mitigate their effects, preventing escalation
- The apex of this characterization is 'breaches,' which signify a successful penetration or circumvention of security measures, leading to unauthorized access or extraction of data



Cloud Incident Response (IR) Lifecycle



Based on NIST 800-61rev2 (Post Incident Analysis replaces Post Mortem)



Preparation

- Establish an incident response process
- Build an IR team and assign roles and responsibilities
- Train the team and run workshops and exercises
- Institute a communication plan and facilities
- Give responders access to environments and tools like incident analysis services, hardware, and software
- Gather internal documentation (e.g., port lists, asset lists, network traffic baseline)
- Subscribe to third-party threat intelligence services



Preparation

- Assess infrastructure with proactive scanning and monitoring, vulnerability and risk assessments
- Evaluate CSPs and their capabilities to aid in incident response regarding the services/resources consumed
 - Audit logs, snapshots, forensics capabilities, and e-discovery features
- Conduct backup restoration testing regularly and disaster recovery (DR) tests at least once per year to ensure that incident response plans are up-to-date and effective



Detection and Analysis

- Detection engineering including CSPM, SIEM and SOAR, workload protection, and monitoring
- Validate alerts (reduce false positives) with escalation
- Estimate the scope of the incident
- Determine the extent of the potential data loss or impact
- Assign an Incident Manager to coordinate actions
- Build a timeline of the attack if applicable
- Notify and coordinate activities
- Communicate the incident containment and recovery status to senior management



Containment, Eradication, and Recovery

- Isolate the incident to prevent further damage and remove the root cause
- Containment: Isolate identities and workloads, taking systems or services offline, and consider the tradeoffs between data loss versus service availability
- Eradication and recovery: Clean up compromised assets and restore systems and services to normal operation. Deploy controls to prevent similar incidents
- Document the incident and gather forensic evidence (e.g., chain of custody)



Post Incident Analysis

- Learn from the incident, document, and improve future responses
- Generate After-Action Reports (AAR) following the exercises and real-world-events
- Populate the Lessons Learned database:
 - Which detections worked, and which alerts fired properly?
 - What detections and protections need to be created based on the event?
 - What improvements does the incident response process need to make?
 - What Indicators of Compromise (IOC) were discovered and were they shared with the community?

Cloud System Forensics

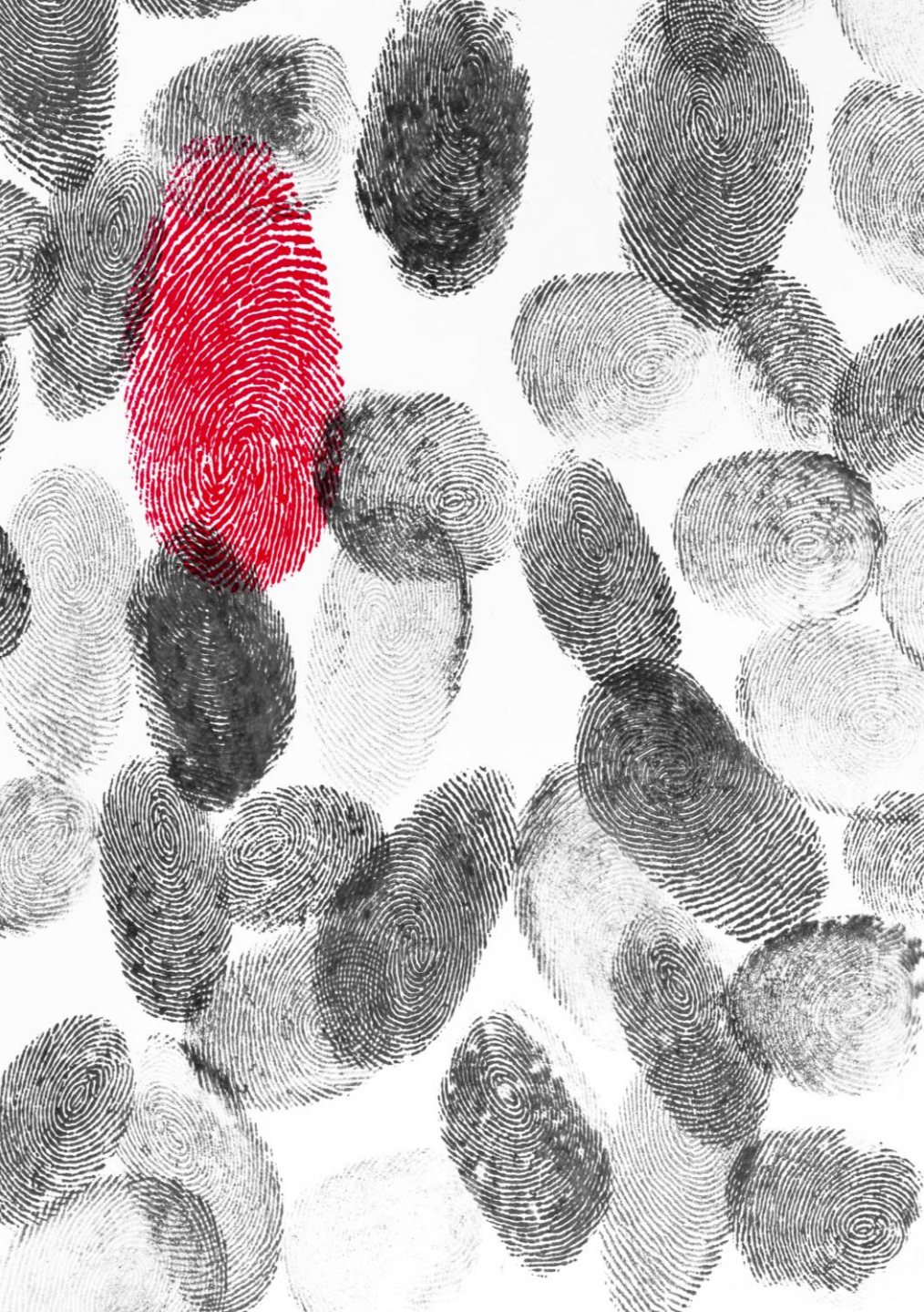
- Cloud forensics falls into two major categories:
 - Analysis of management plane, service, and other logs
 - System forensics for virtual machines (VMs) and containers
- Traditional digital (systems) forensics methodologies often rely on physical access to hardware and local data storage, **which is not possible in the cloud**
- Instead, cloud forensics requires incident response teams to work within the constraints and capabilities provided by CSPs





Key Aspects of Cloud Forensics

- **Snapshots:** Nearly all CSPs and container management systems support snapshots which can be used for forensics analysis
 - A CSC should grasp how and why to take snapshots of storage volumes immediately when an incident is detected to preserve the state of the VM for analysis
- **Volatile memory acquisition:** Without the ability to instrument hardware, if memory forensics is required, the responders will need to install software tools which will also affect the system



Key Aspects of Cloud Forensics

- **Log analysis:** Management plane logs, along with system, application, and user activity logs, can also be used to present a fuller picture of incidents even when the focus is on VMs/containers
 - They can, for example, help identify an attacker who obtained system credentials and pivoted to the management plane
- **Evidence preservation:** Preserving digital evidence in cloud environments requires a thorough understanding of the backup and data retention policies of both the CSP and the CSC and the chain of custody of snapshots

Zero Trust

- Zero Trust is a security model that eliminates implicit trust and continuously verifies every access request based on multiple factors, including identity, device, and context
- It assumes that threats exist both inside and outside the network and enforces strict access controls
- This initiative will implement services and tools for mass visibility of the context of all subjects and resource objects



Zero Trust Objectives

- **Protective Framework:** ZT's core assumption is that an organization should not inherently trust any subject within or beyond its boundaries
- **Simplified User Experience:** Zero Trust Architecture (ZTA) streamlines access by using a consistent model for all requests, eliminating complicated access controls and ensuring just-in-time authorization





Zero Trust Objectives

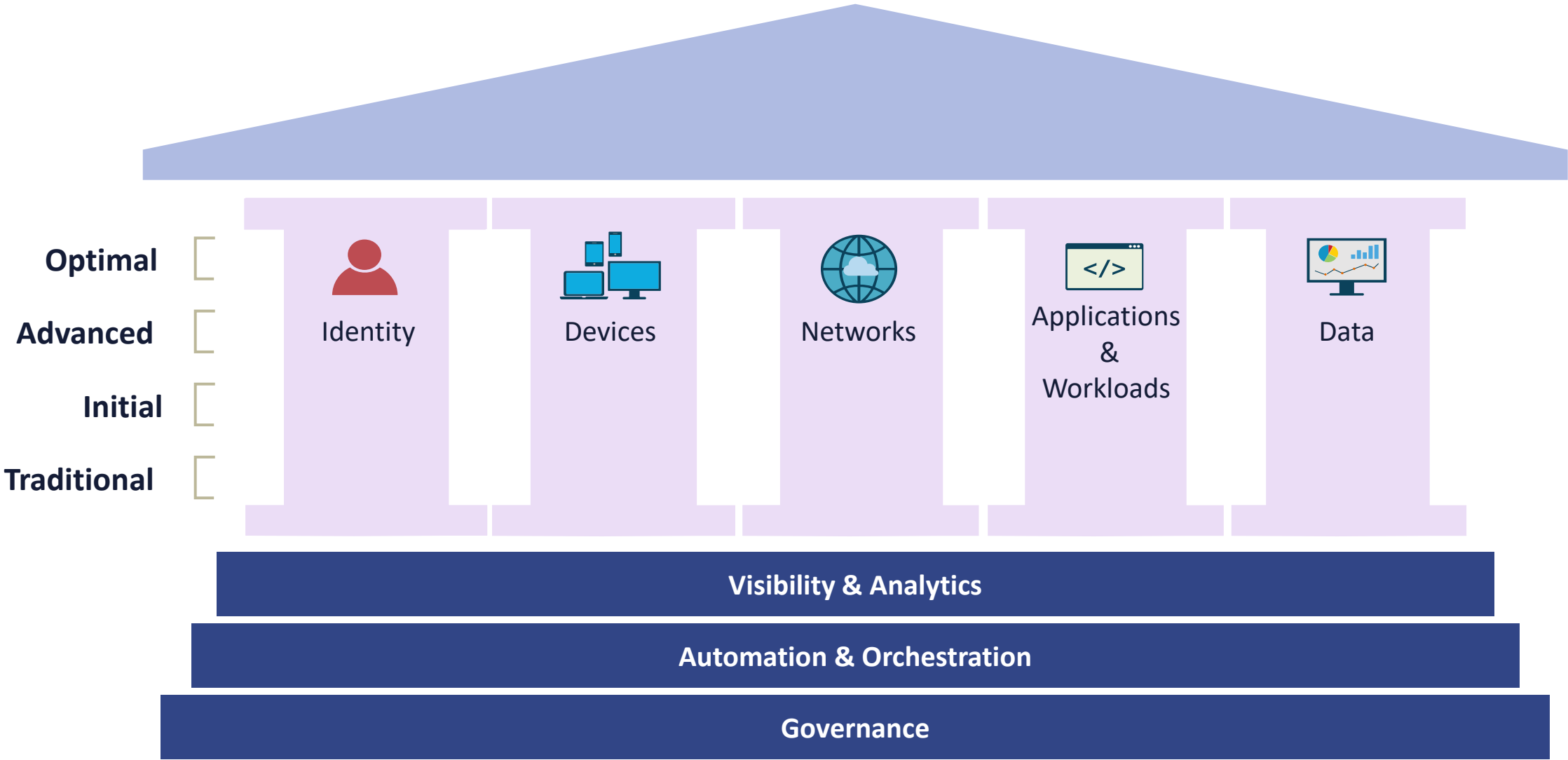
- **Reduced Attack Surface:** ZTA implements strict access controls, continuous authentication, and least privilege principles across the entire network and infrastructure
- **Reduced Complexity:** ZT reduces IT complexity by creating focused security perimeters around applications and identities, simplifying access control in hybrid, multi-cloud, and edge computing environments

Zero Trust Objectives

- **Enforce Principles of Least Privilege:** Ensuring that subjects have only the necessary privileges for their tasks, simplifying security management and improving user experience
- **Improved Security Posture and Resilience:** A reduced attack surface improves the security posture and makes recovery easier
- **Improved Incident Containment and Management:** The micro-segmentation and continuous authorization for network access reduces the blast radius and allows for better control over an attacker's lateral movement



CISA Zero Trust Maturity Model



CCSK Domains Mapped to Zero Trust Principles

Security Domain	Zero Trust Principle
Organizational Management	ZT as an enterprise security and connectivity strategy, best implemented with a ZT culture
Identity and Access Management	Continuous, phishing-resistant MFA with context-based authorization of users, devices, and access requests
Security Monitoring	Monitor everything; presume breaches, detect suspicious activity early and dynamically adjust access
Network	Micro-segmentation, ZT Network Architecture & Software-Defined Perimeter
Workload	ZT device and workload security and integrity verification, malware and data exfiltration monitoring , with ZT workload access controls
Application	Fine-grained, least privilege access authorization with separation of duties; limit user permissions to the minimum required data and functionality
Data	Classify, protect, and monitor data at rest, in transit, and in use with strict ZT data access controls

CCSK Domains Mapped to ZT Principles

Security Domain	Zero Trust Principle
Organizational Management	ZT as an enterprise security and connectivity strategy, best implemented with a ZT culture
Identity and Access Management	Continuous, phishing-resistant MFA with context-based authorization of users, devices, and access requests
Security Monitoring	Monitor everything; presume breaches, detect suspicious activity early, and dynamically adjust access
Network	Micro-segmentation, ZT Network Architecture & Software-Defined Perimeter
Workload	ZT device and workload security and integrity verification, malware and data exfiltration monitoring, with ZT workload access controls
Application	Fine-grained, least privilege access authorization with separation of duties; limit user permissions to the minimum required data and functionality
Data	Classify, protect, and monitor data at rest, in transit, and in use with strict ZT data access controls

CSA Cloud Controls Matrix (CCM) and the Consensus Assessment Initiative Questionnaire (CAIQ)

- The CCM is 197 control objectives structured in 17 domains covering all key aspects of cloud technology
- Often used for the systematic assessment of a cloud implementation
- Offers guidance on which security controls should be implemented by which actor within the cloud supply chain
- It is considered the de-facto standard for cloud security assurance and compliance
- The STAR Level 1: Security Questionnaire (CAIQ v4) offers an industry-accepted way to document what security controls exist in IaaS, PaaS, and SaaS services

CCM Domains

- Application & interface security (AIS)
- Audit assurance & compliance (AAC)
- Business continuity management & operational resilience (BCR)
- Change control & configuration management (CCC)
- Data security & information lifecycle management (DSI)
- Datacenter security (DCS)
- Encryption & key management (EKM)
- Governance & risk management (GRM)
- Human resources (HRS)
- Identity & access management (IAM)
- Infrastructure & virtualization security (IVS)
- Interoperability & portability (IPY)
- Mobile security (MOS)
- Security incident management, eDiscovery, & cloud forensics (SEF)
- Supply chain management, transparency, and accountability (STA)
- Threat & vulnerability management

Download the CCM Bundle

- For this open book CCSK exam be sure to download the CCM bundle which includes the matrix and questionnaire Excel spreadsheets
- Have them open while taking the exam
- Practice quickly searching based on keywords
- Go to:

<https://cloudsecurityalliance.org/artifacts/cloud-controls-matrix-v4/>

The European Union Agency for Cybersecurity

ENISA

- ENISA, is the EU's agency committed to attaining a high collective level of cybersecurity across Europe
- It was created in 2004 and strengthened by the EU Cybersecurity Act
- The goals of ENISA are as follows:
 - Contribute to EU cyber policy
 - Improve the trustworthiness of information and communications technology (ICT) products, services and processes with cybersecurity certification schemes
 - Cooperate with Member States and EU bodies
 - Assist Europe to prepare for future and emerging cyber challenges

ENISA Offerings

- Empowering communities
- Cybersecurity policy
- Operational cooperation
- Capacity building
- Trusted solutions
- Foresight and Knowledge

<https://www.enisa.europa.eu/media/news-items/cloud-computing-speech>

<https://www.enisa.europa.eu/publications/cloud-computing-risk-assessment>

